



Securing User, Application, and Data Access

AWS Academy Cloud
Architecting



Introduction

Securing User, Application, and Data Access

Module objectives

This module prepares you to do the following:

- Use AWS Identity and Access Management (IAM) users, groups, and roles to manage permissions.
- Implement user federation within an architecture to increase security.
- Describe how to manage multiple AWS accounts.
- Recognize how AWS Organizations service control policies (SCPs) increase security within an architecture.
- Encrypt data at rest by using AWS Key Management Service (AWS KMS).
- Identify appropriate AWS security services based on a given use case.

Module overview

Presentation sections

- Managing permissions
- Federating users
- Managing access to multiple accounts
- Encrypting data at rest
- AWS security services for securing user, application, and data access

Knowledge checks

- 10-question knowledge check
- Sample exam question

Hands-on labs in this module

Guided labs

- Securing Applications by Using Amazon Cognito
- Encrypting Data at Rest by Using AWS Encryption Options

As a cloud architect designing for application security



- I need to design permissions schemes for users, applications, and data that align to security best practices and are scalable.
- I need to prevent unauthorized access to data and applications and protect the data that's being stored within the application architecture.
- I need to evaluate purpose-built AWS security services to select options that optimize the security of my applications with less undifferentiated lifting by our internal security team.



Managing permissions

Securing User, Application, and Data Access

Challenge of managing permissions

Assigning permissions directly to users is difficult to manage

IAM
user policy

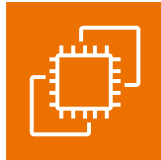


Attach



John

Access



Amazon EC2

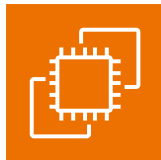


Attach



Mary

Access



Amazon EC2

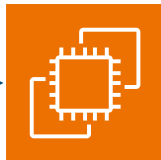


Attach



Pat

Access



Amazon EC2

Initial configuration

Each developer is given full access to Amazon Elastic Compute Cloud (Amazon EC2) through policies that are attached to individual users.

Additional access is needed

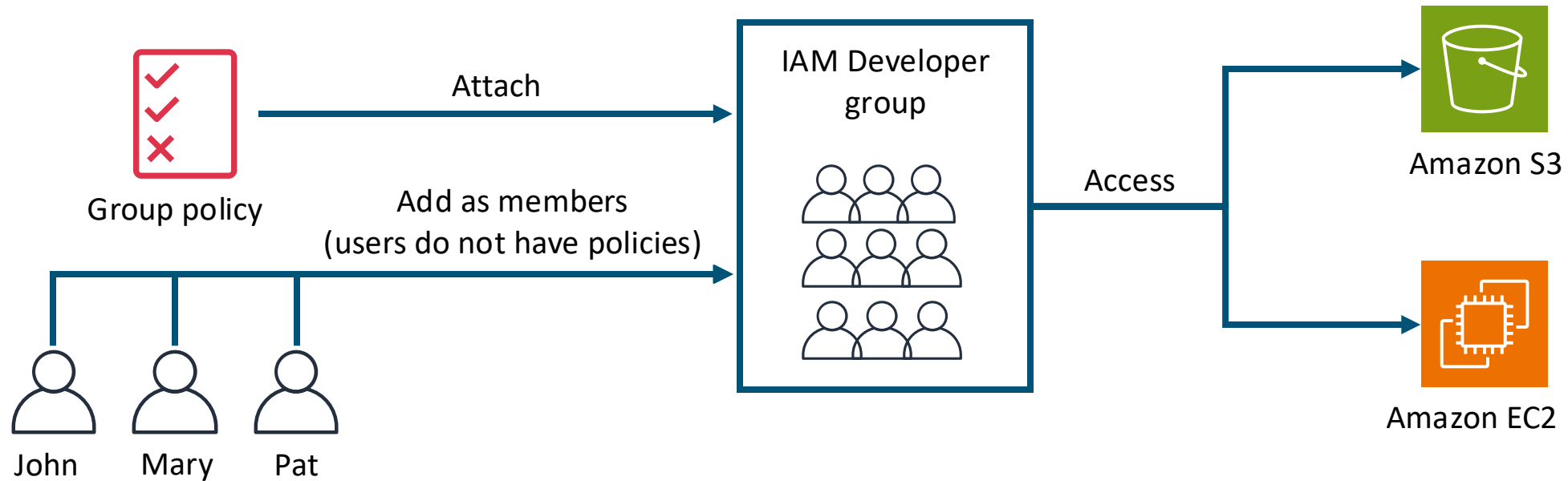
Each developer needs access to Amazon Simple Storage Service (Amazon S3). To implement this change, an administrator needs to make three modifications, one for each AWS Identity and Access Management (IAM) user's policy.

The number of developers grows

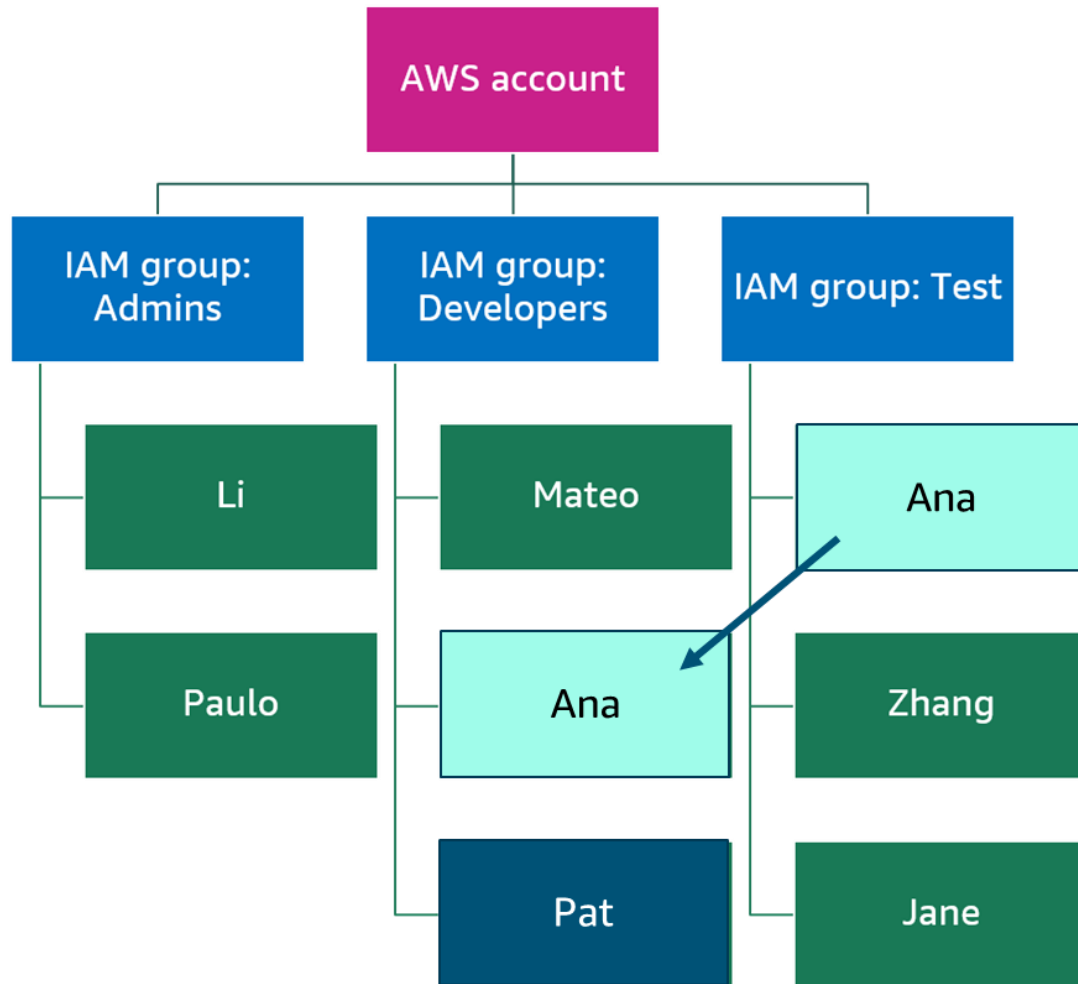
This approach becomes hard to manage. Is there an easier way to manage multiple permissions and users?

Use IAM groups to attach permissions to multiple users

- Permissions in a group can be based on a job function.
- All users in the group inherit the permissions assigned to the group.



Example: Using IAM groups to reflect job role



If a new developer (Pat) is hired, add them to the developers group. Pat will immediately inherit the same access that's granted to other developers.

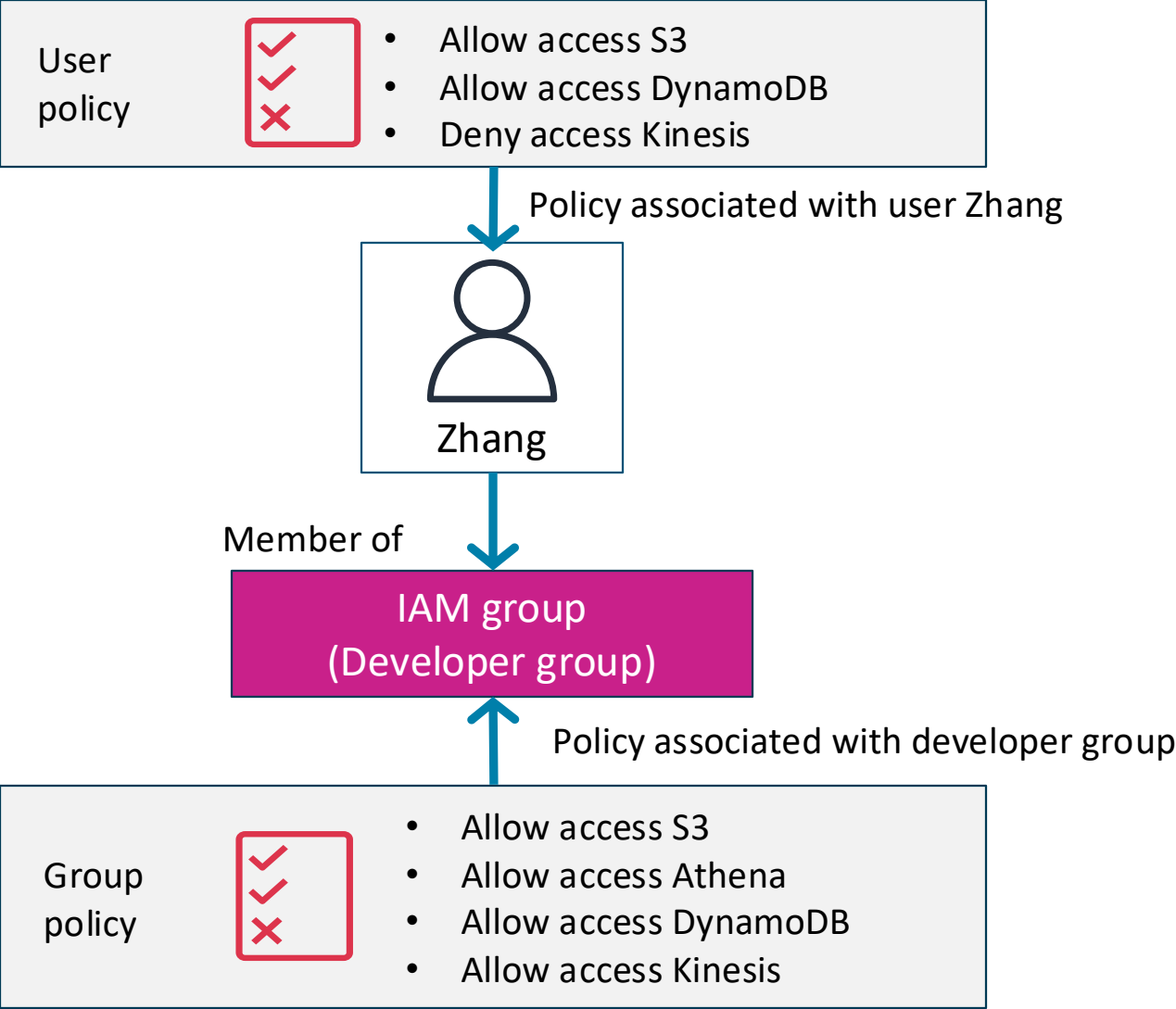
If Ana takes on the new role of developer, do the following:

- Remove her from the test group.
- Add her to the developers group.

Users can belong to more than one group, but groups cannot be nested.

Permissions in policies directly attached to a user (user policies) override permissions in group policies if they are more restrictive.

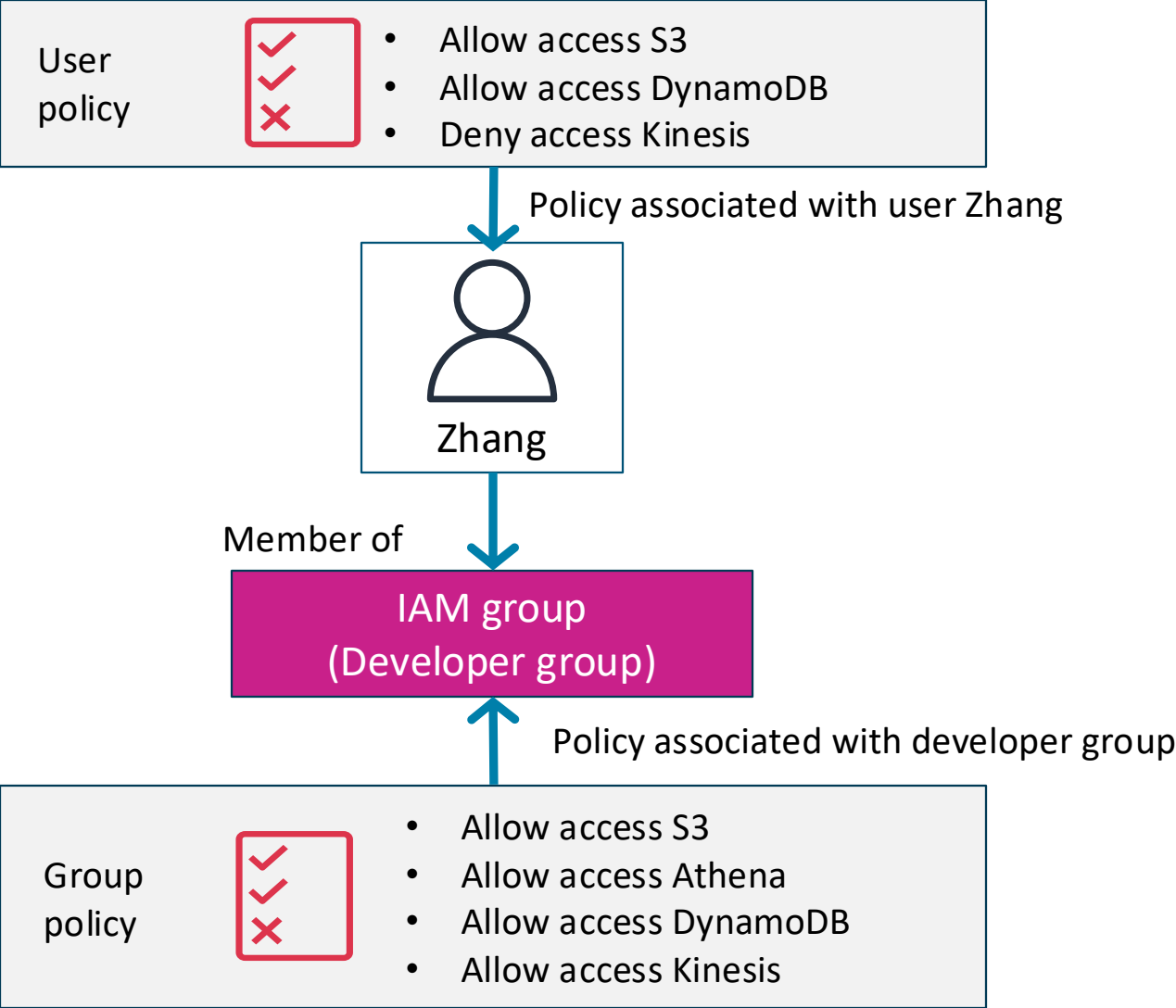
Example: Using a user policy and group policy together



Can Zhang access Amazon Athena?

Can Zhang access Amazon Kinesis?

Example: Resulting permissions



Zhang can access Athena

Zhang is a member of a developer group. The developer group allows access to Athena.

Zhang cannot access Kinesis

Zhang is a member of a developer group that allows Kinesis access. But the user policy explicitly denies access to Kinesis.

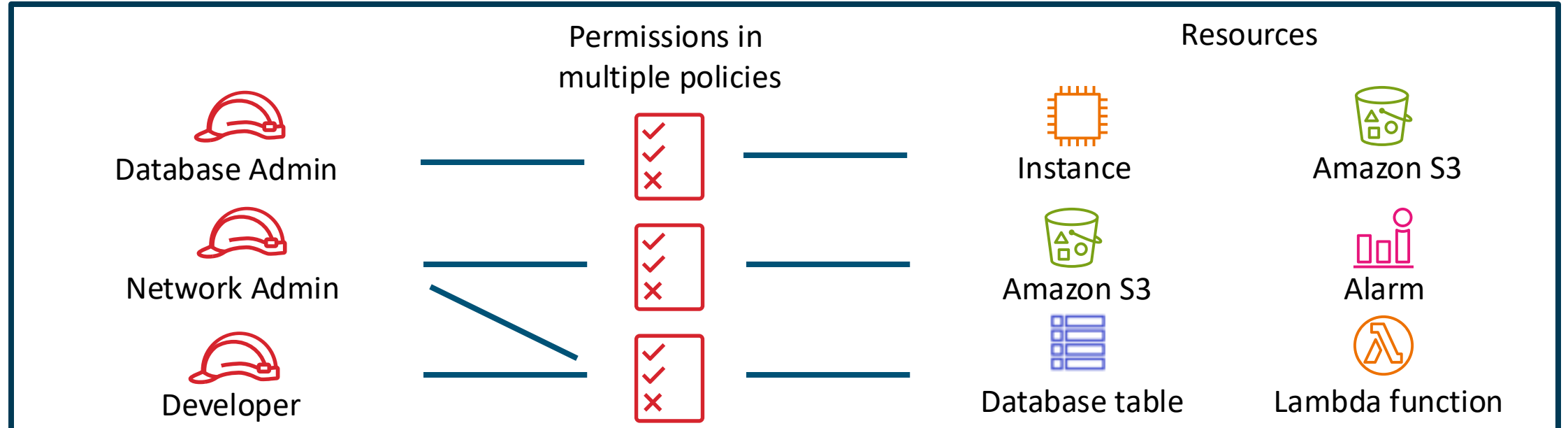
Challenges of scaling with role-based access control (RBAC)

To setup RBAC with IAM, do the following:

- Create an IAM policy with the permissions for the job role. The policy lists the individual resources to be accessed.
- Attach the policy to an IAM entity (user, group, or role).

To update policies when access to a new resource is needed, do the following:

- Update the policy.
- Modify multiple policies if the new resource is used by multiple roles or to add access to multiple resources.



Using attribute-based access control (ABAC)

ABAC

- This authorization strategy defines permissions based on attributes.
- Attributes are a key or a key-value pair.
- In AWS, these attributes are called tags.
- Tags can apply to IAM resources (users or roles) and AWS resources.

Benefits

- It's more flexible than policies that require you to list each individual resource.
- Granular permissions are possible *without* a permissions update for every new user or resource.
- It's a highly scalable approach to access control.
- It's fully auditable.

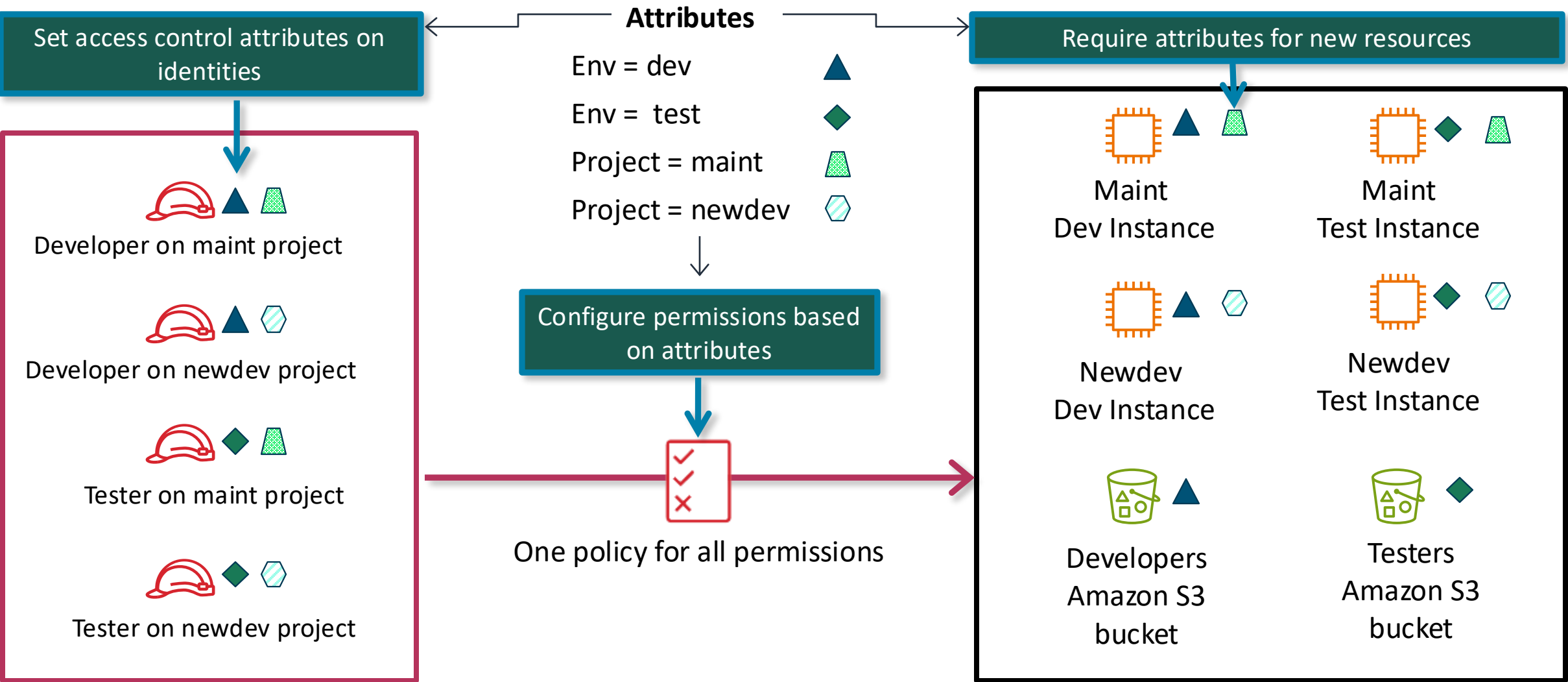
Tagging in AWS

- Tags are resource metadata consisting of a key/value pair.
- Tags can apply to resources across AWS accounts and IAM users or roles.
- Customers can create user-defined tags.
- Many different AWS API operations return tag keys and values.
- Tags have multiple practical uses like billing, filtered views, and access control.

Example tags applied to an EC2 instance

Key	Value
Name	Web server
Project	Unicorn
Env	Dev

Example: Using ABAC to grant permissions in one policy



Key takeaways: Managing permissions



- Use IAM groups to grant the same access rights to multiple users. Create groups that reflect job functions.
- Use ABAC rather than RBAC to scale permissions management.
- ABAC is an authorization strategy that defines permissions based on attributes. It simplifies access control management by combining permissions into a single policy.
- Attributes are key value pairs. AWS enables customers to assign attributes to their AWS resources and identities in the form of tags.



Federating users

Securing User, Application, and Data Access

Identity federation

A system of trust between two parties to authenticate users and convey information that's needed to authorize access to resources

- Identity provider (IdP) is responsible for user authentication.
- Examples:
 - OpenID connect (OIDC) IdPs like Login with Amazon, Facebook, and Google
 - Security Assertion Markup Language (SAML) IdPs like Shibboleth or Active Directory Federation Services
- Service provider (SP) is responsible for controlling access to its resources.
- Examples
 - AWS services
 - Social media platforms
 - Online bank

AWS services that support identity federation



- AWS Identity and Access Management (IAM)



- AWS IAM Identity Center (successor to AWS Single Sign-On)

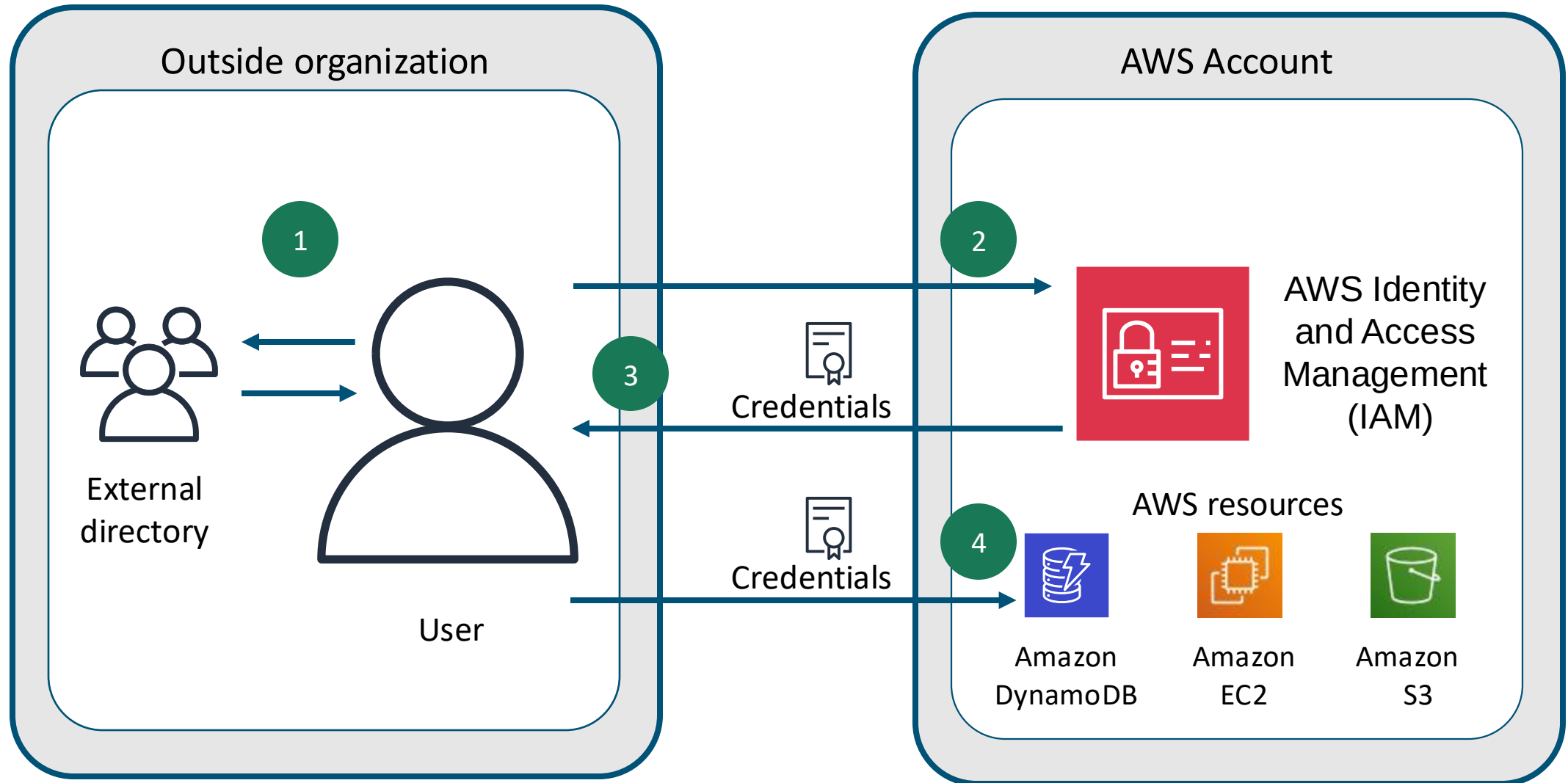


- AWS Security Token Service (AWS STS)



- Amazon Cognito

Workforce identity federation



AWS IAM Identity Center



IAM Identity Center

- Successor to AWS Single Sign-On
- Can create or connect identities once and manage access centrally across your AWS accounts
- Provides a unified administration experience to define, customize, and assign fine-grained access
- Provides a user portal to access all assigned AWS accounts or cloud applications
- Used optionally in conjunction with IAM

AWS Security Token Service (AWS STS)



AWS STS

- AWS STS is a web service (API) that enables you to request temporary, limited-privilege credentials.
- The credentials can be used by IAM users, federated users, or applications.

Identity federation to AWS with an identity broker

User signs in with existing credentials for their IdP

- Users sign in using an identity that is already known by an IdP (for example their Amazon.com ID or a corporate login).

Identity broker acts as an intermediary between IdP and SP

- The identity broker requests temporary credentials from AWS STS.

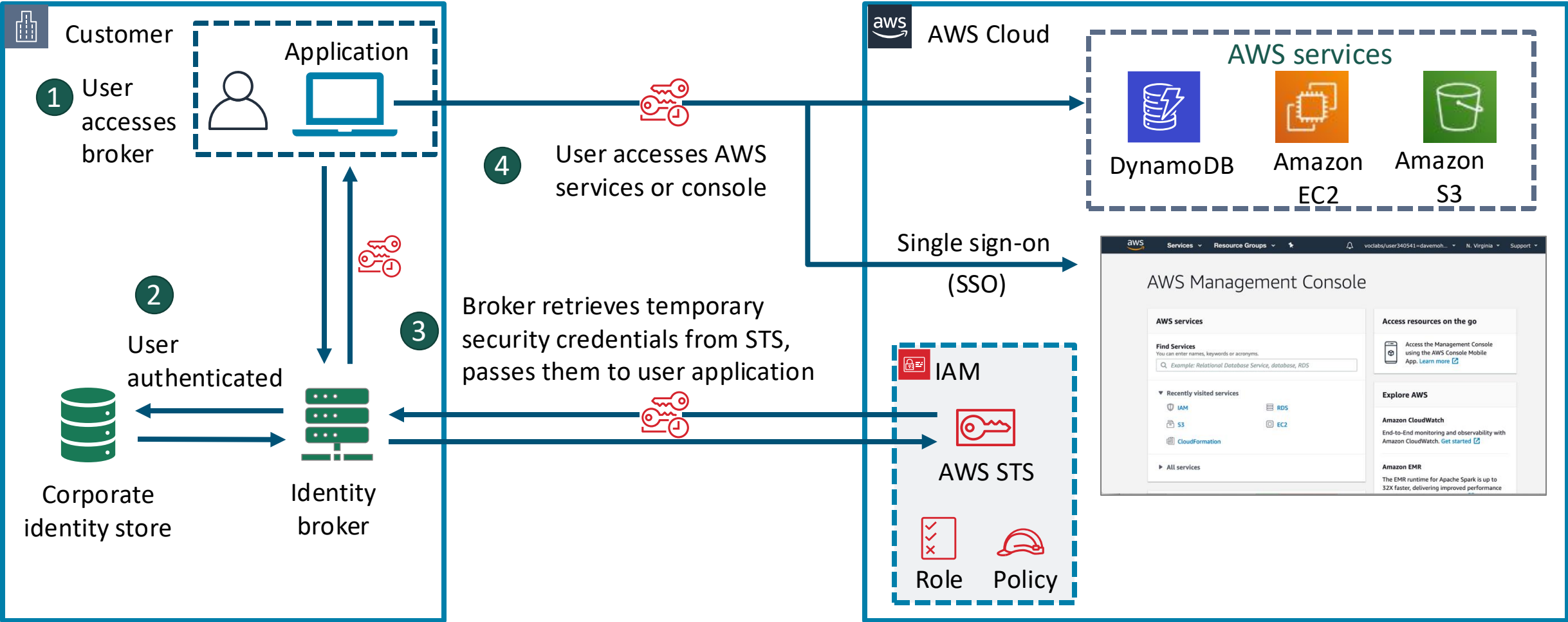
AWS STS generates temporary credentials dynamically

- The credentials last from a few minutes to several hours and are not recognized after the credentials expire.

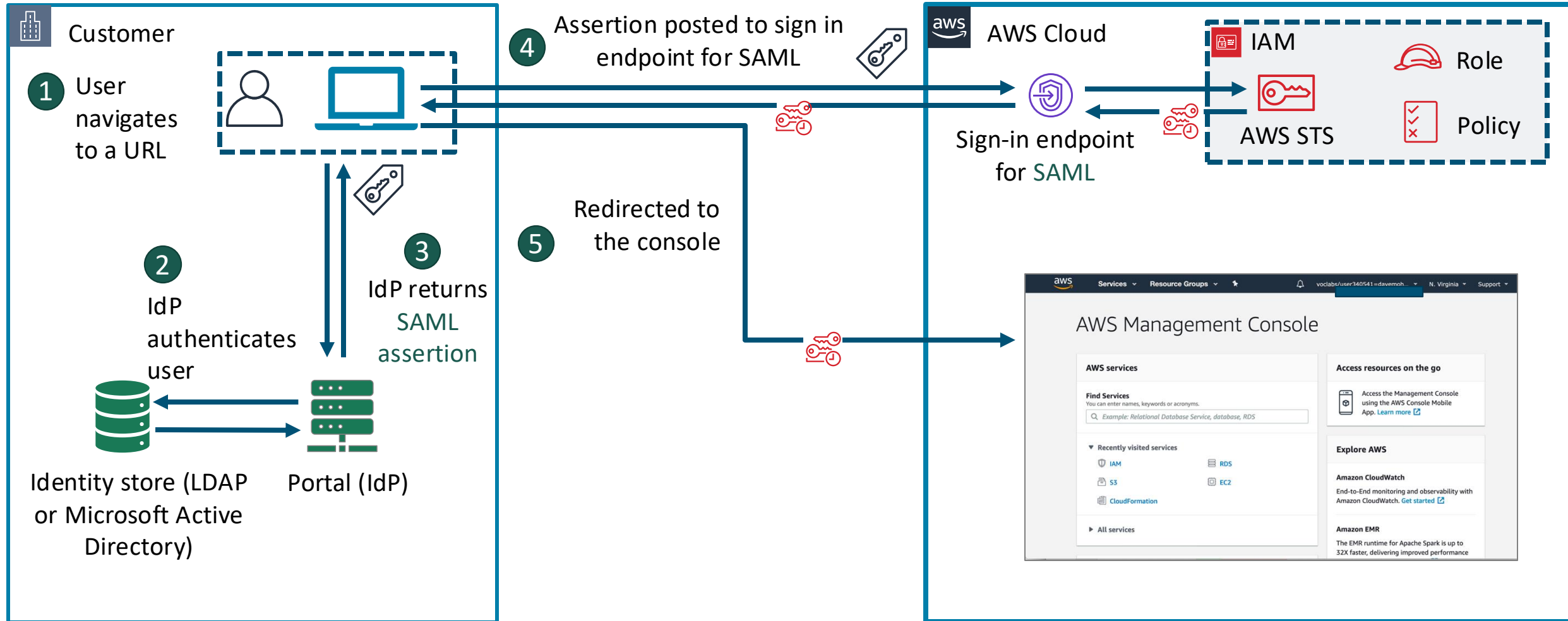
Identity broker passes temporary credentials to application

- AWS STS returns the temporary credentials to the identity broker.
- The identity broker passes them to the application for the user.

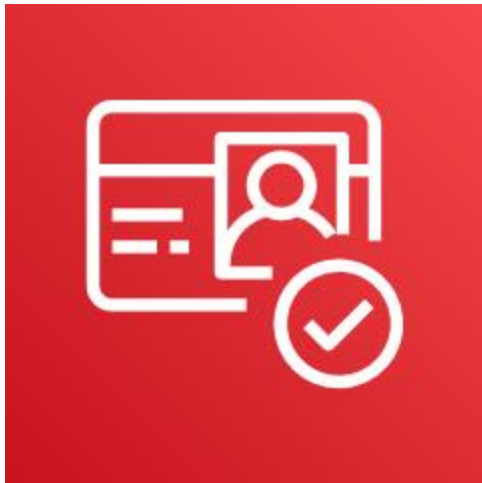
Example: Identity federation for AWS Management Console access



Example: Identity federation for AWS Management Console using SAML



Amazon Cognito

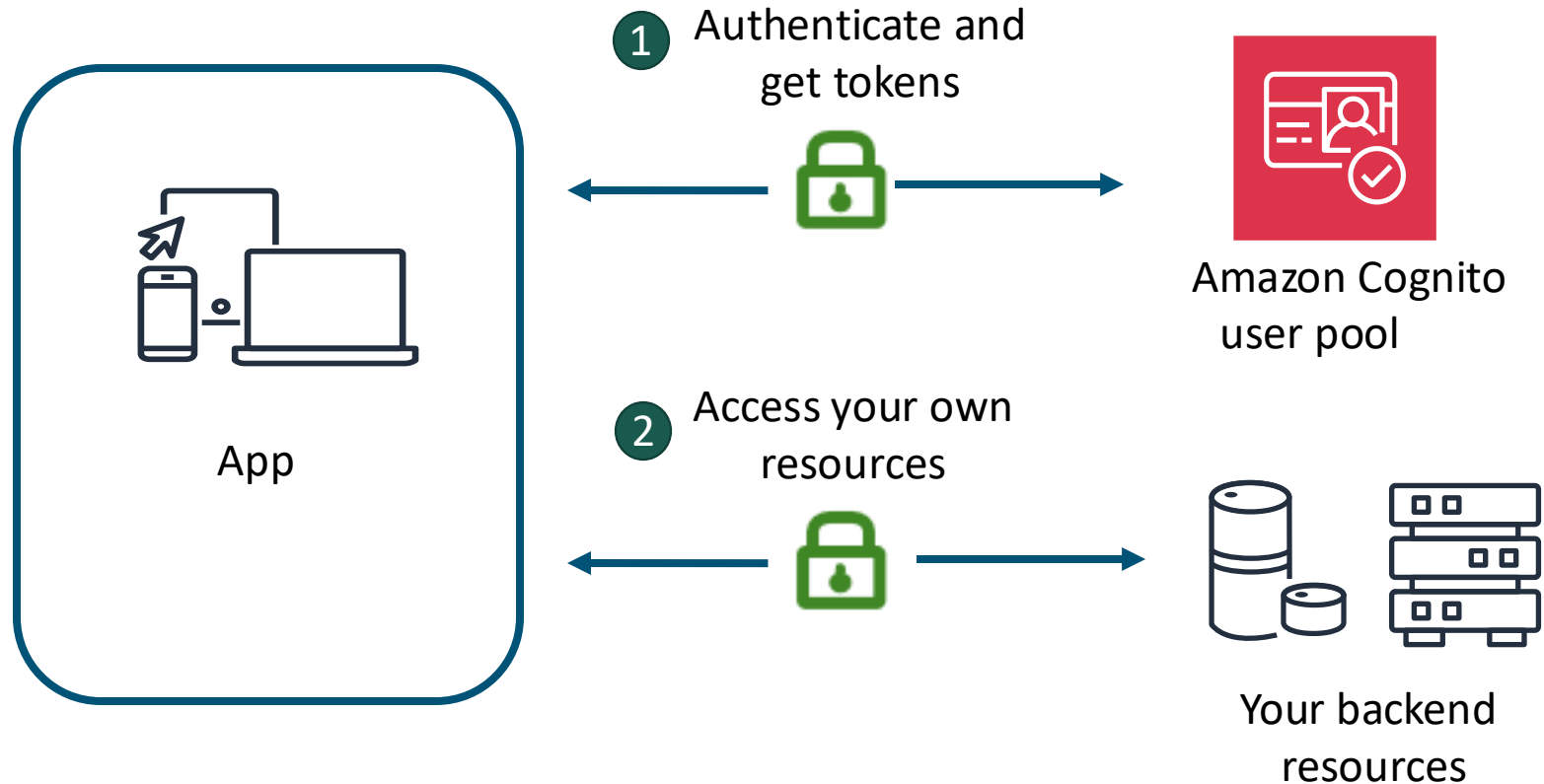


Amazon Cognito

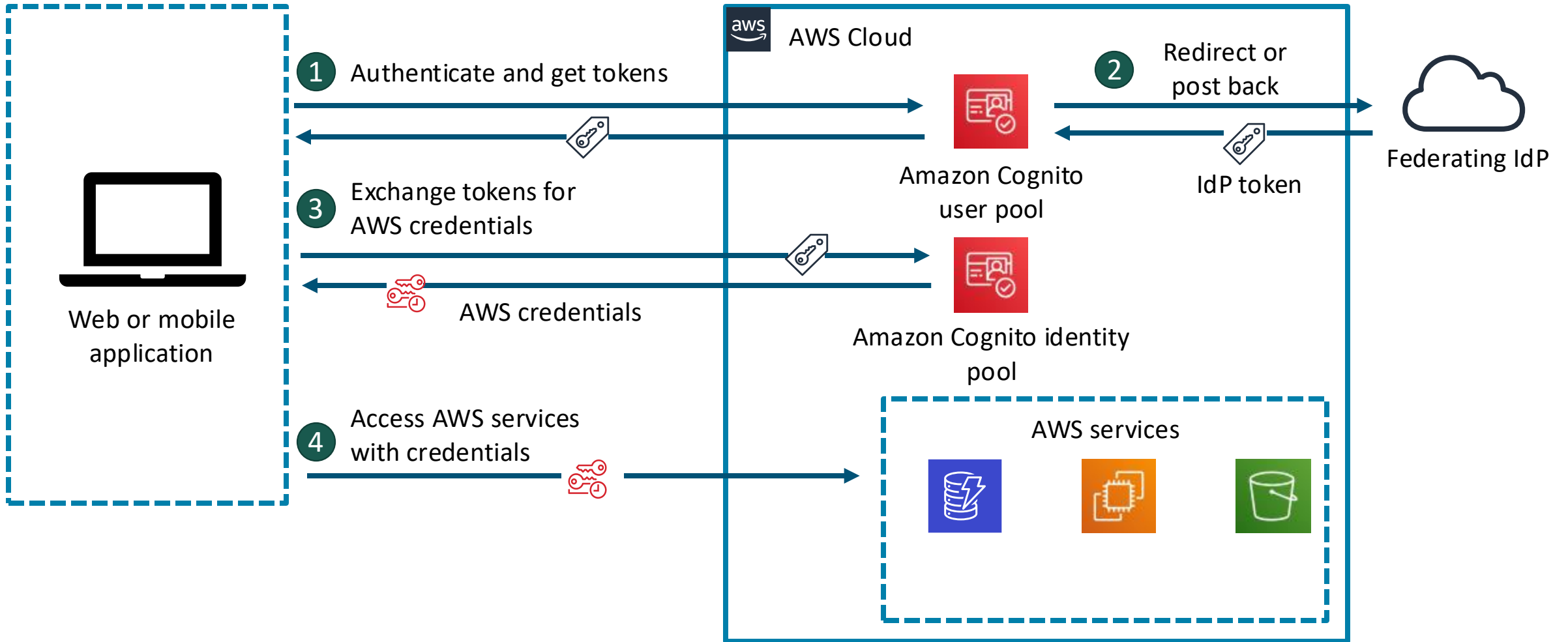
A fully managed service that provides the following services and features:

- Authentication, authorization, and user management for web and mobile applications
- Federated identities for sign in with social identity providers (Amazon, Facebook, Google) or with SAML
- User pools that maintain a directory with user profiles authentication tokens
- Identity pools that enable the creation of unique identities and permissions assignment for users

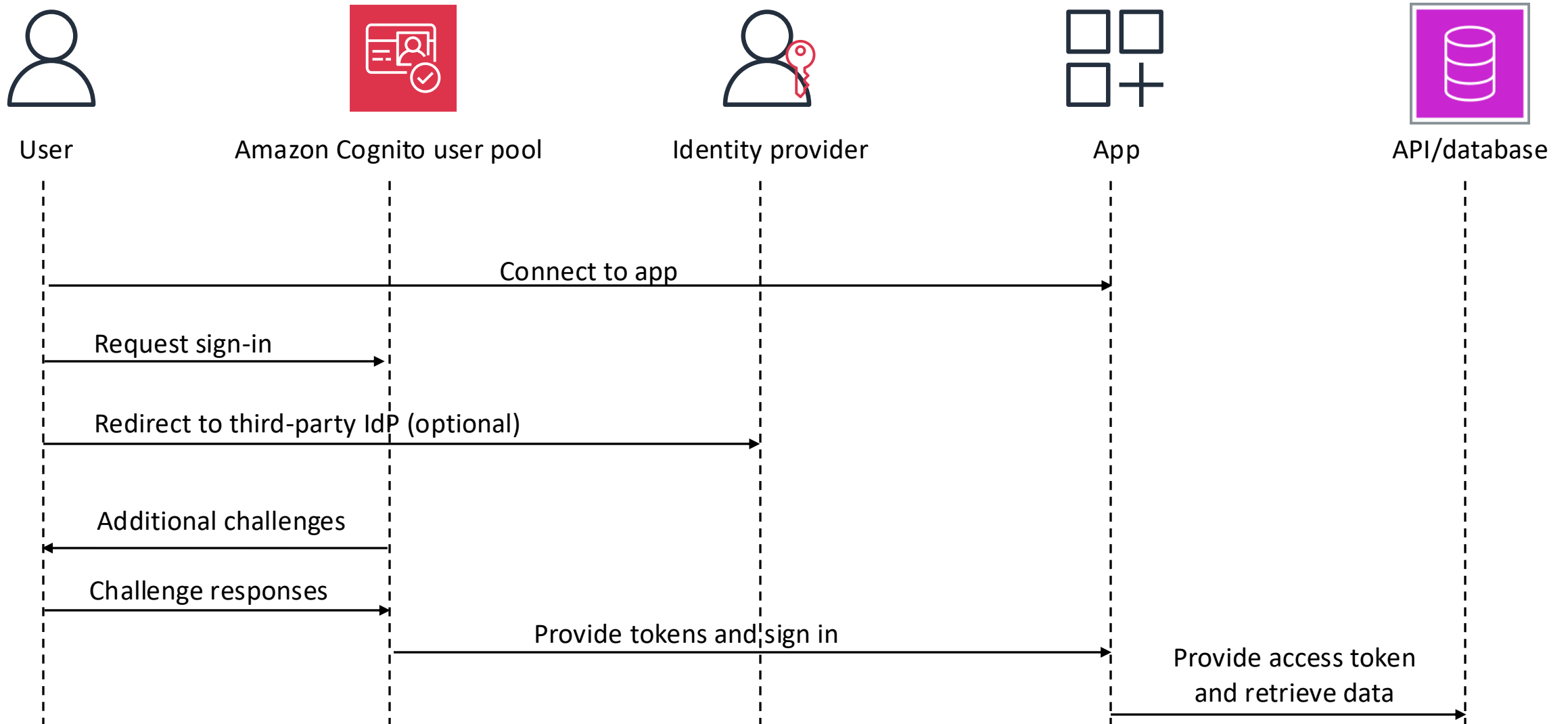
Application access identity federation



Amazon Cognito example



Amazon Cognito user pools



Amazon Cognito user pools features

Feature	Description
Sign-up	• Let users enter their information in your app and create a user profile that's native to your user pool. • Redirect users to a third-party IdP that they can authorize to pass their information to Amazon Cognito. • Create users based on a data source or schema.
Sign-in	• Use as a standalone user directory and IdP to your app.
Federate third-party identities	• Let the user pool manage the overhead of handling the tokens that are returned from social sign-in through Facebook, Google, Amazon, and Apple, and from OIDC and SAML IdPs.
Hosted UI for sign-up and sign-in	• Present users with customized Amazon Cognito hosted web pages for sign-up, sign-in, multi-factor authentication (MFA), and password reset.
Support for JWTs	• Use JWT tokens to access server-side resources or exchange them for temporary AWS credentials to access other AWS services. JWT is an open standard that defines a compact, self-contained way to securely transmit information between parties as a JSON object.
User pool groups	• Use groups to create collections of users to manage their permissions or to represent different types of users. For example, create separate groups for users who are readers, contributors, and editors of your website and app.

Key takeaways: Federating users



- Identity federation is a system of trust between IdPs and SPs.
- AWS IAM Identity Center provides a unified administration experience to define, customize, and assign fine-grained permissions based on common job functions.
- AWS STS is a web service that provides temporary AWS credentials and allows an IAM user, federated user, or application to assume an IAM role.
- An identity broker facilitates federation when users already have identities outside of AWS, such as a corporate directory.
- Amazon Cognito is a fully managed service that provides authentication, authorization, and user management for web and mobile applications. Users can sign in directly or through a third party, such as Facebook, Amazon, or Google.



Guided lab: Securing Applications by Using Amazon Cognito (Amazon Cognito lab)

Lab introduction: Amazon Cognito lab



- In this lab, you use the Amazon Cognito service to authenticate users of a web application.
- The tasks that you perform include the following:
 - Creating an Amazon Cognito user pool to store and manage the application users
 - Configuring a user pool to provide a hosted UI for the application
 - Using the user pool to authenticate access to a protected application function
- Open your lab environment to start the lab and find additional details about the tasks that you will perform.

Debrief: Amazon Cognito lab

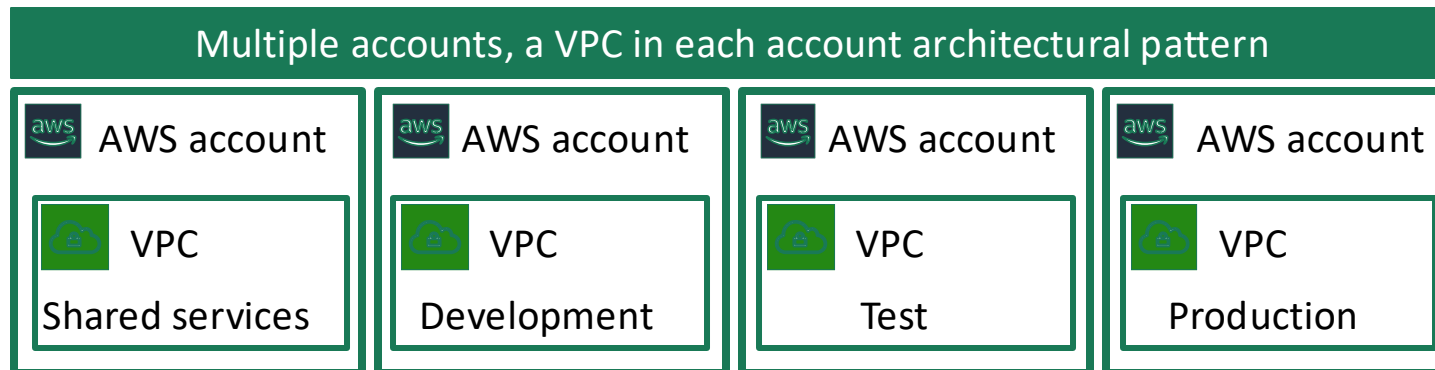
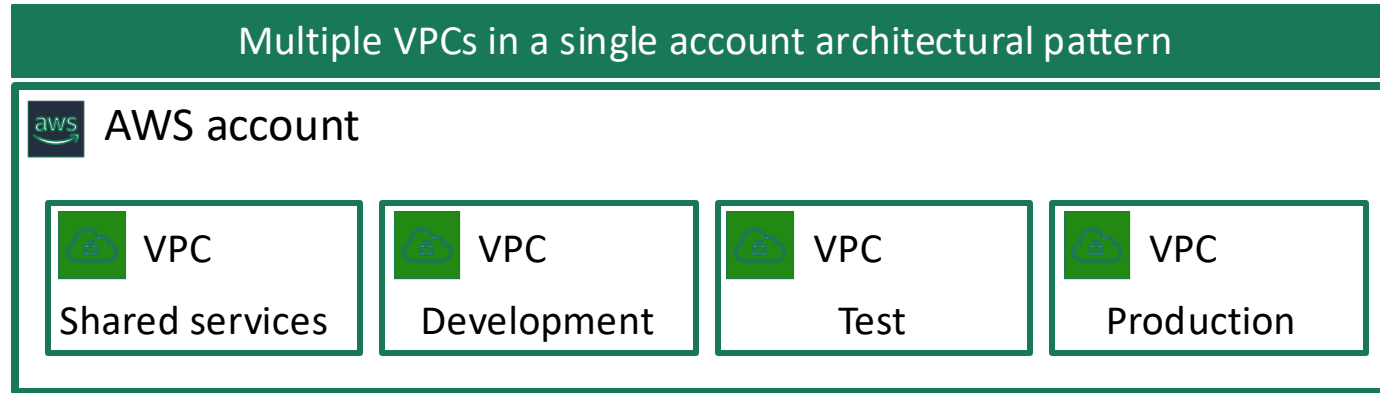
- What did you do to create users and manage user passwords for the Birds website?
- In this lab, you used Amazon Cognito to set up an identity pool. Why did you need an identity pool?



Managing access to multiple accounts

Securing User, Application, and Data Access

Two common patterns for separating resource access



Advantages and challenges of multiple accounts

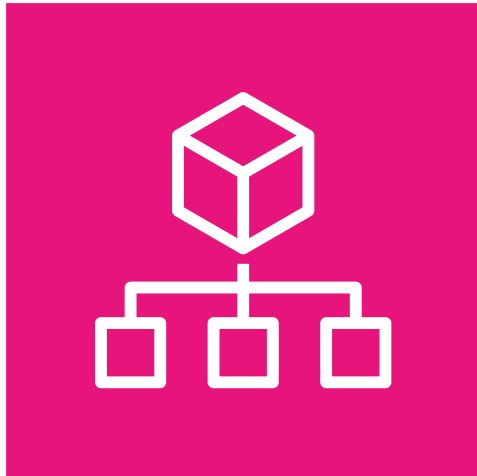
Advantages

- Isolation by business units or departments
- Isolation by environment (for example, development, test, and production)
- Isolation of auditing and recovery data
- Separation of accounts for regulated workloads
- Ease of creating cost alerts for each business unit's consumption
- Cost savings (bulk/volume pricing across accounts)

Challenges

- Security management across accounts
- Manual processes involved in creating many new accounts
- Determination of which organization should be billed
- Need for centralized governance to ensure compliance and consistency

AWS Organizations



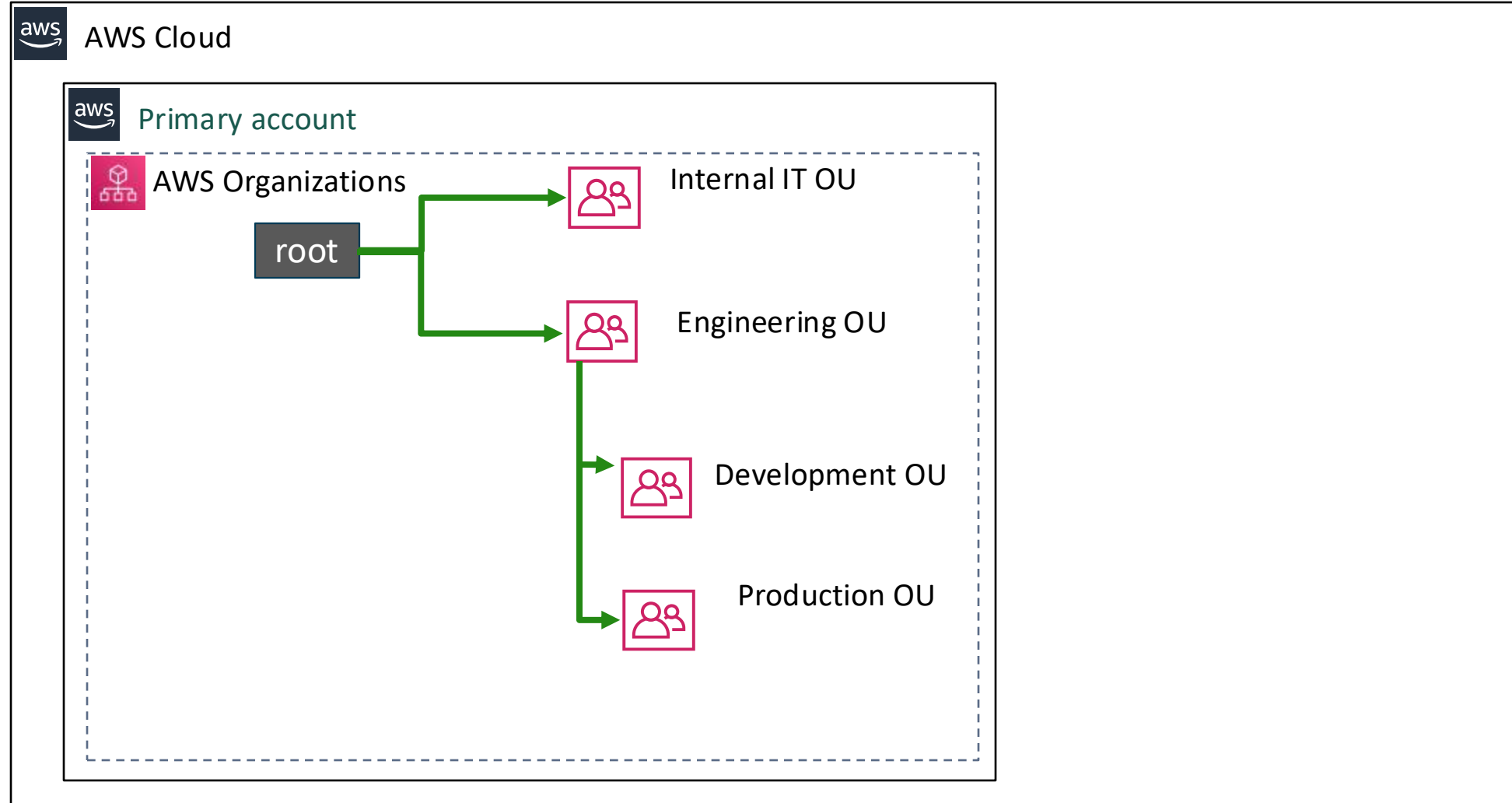
AWS
Organizations

- Account management service that you can use to consolidate multiple AWS accounts into a centrally managed organization
- Tier pricing discounts available
- Includes account creation and management and consolidated billing capabilities
- Provides for hierarchical grouping of accounts
- Supports centralized policy control over AWS services and API actions using service control policies (SCPs)

AWS Organizations: Create organizational units

In the AWS Organizations primary account:

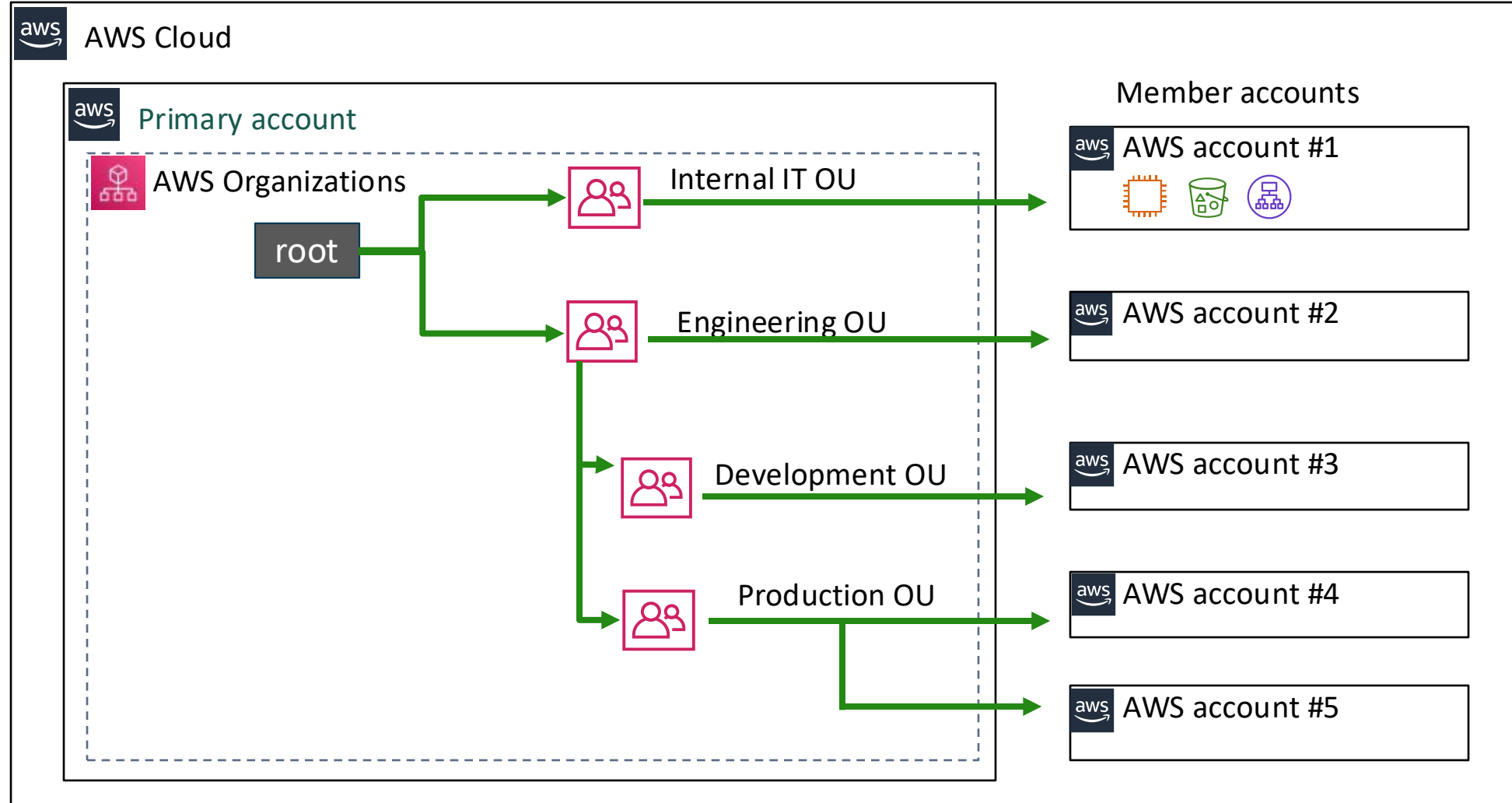
1. Create a hierarchy of organizational units (OUs).



AWS Organizations: Assign accounts

In the AWS Organizations primary account:

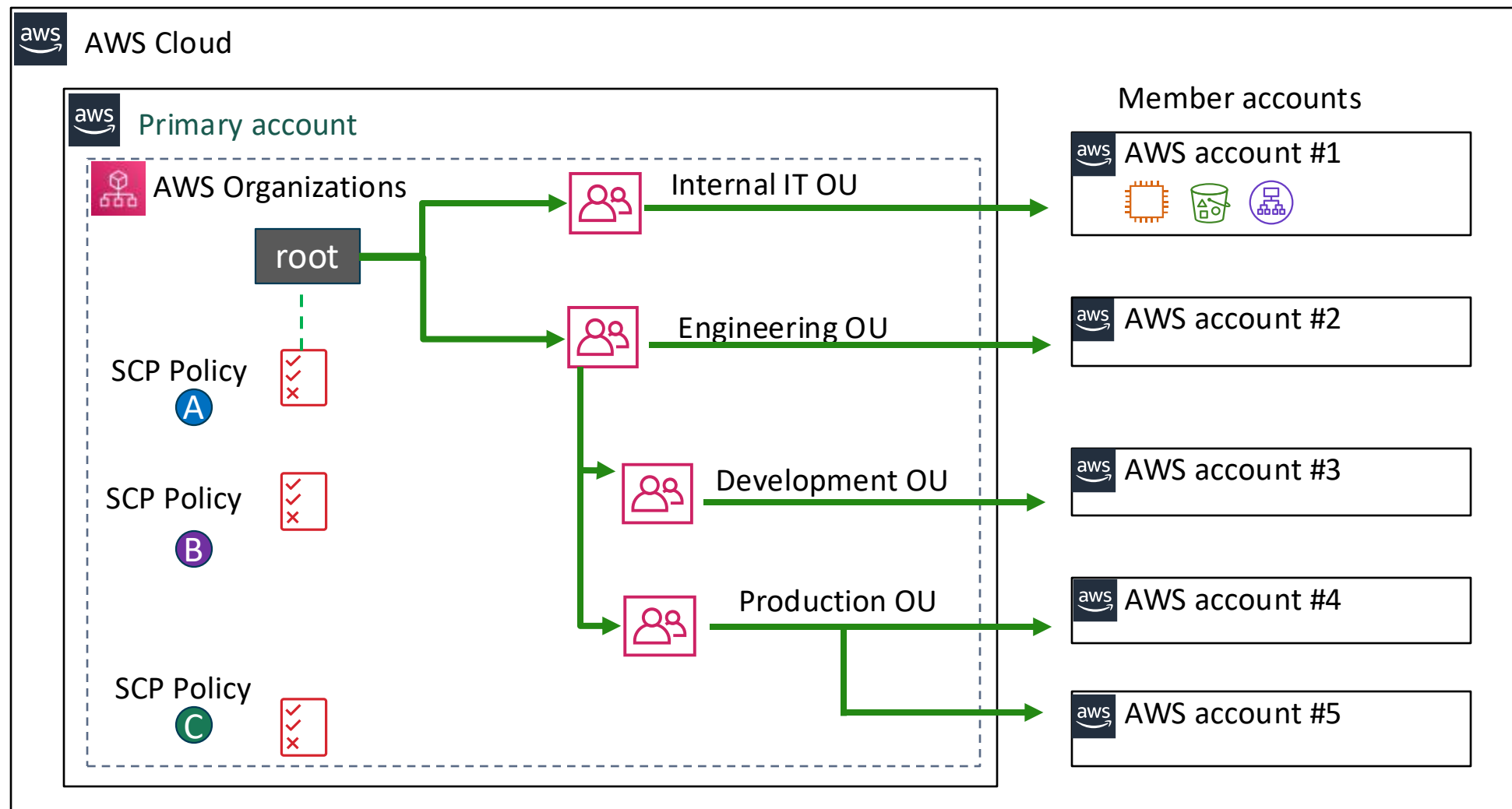
1. Create a hierarchy of organizational units (OUs).
2. Assign accounts to OUs as member accounts.



AWS Organizations: Define SCPs

In the AWS Organizations primary account:

1. Create a hierarchy of organizational units (OUs).
2. Assign accounts to OUs as member accounts.
3. Define SCPs that apply permissions restrictions to specific member accounts.



Organizations SCPs

- Offer central control over the maximum available permissions for all accounts in your organization.
- Enable control of which services are accessible to IAM users in member accounts.
- Define permissions that affect an entire account.
- Define guardrails, or sets limits, on the actions that the account's administrator can delegate to the IAM users and roles in the affected accounts. IAM policies that are defined in individual accounts still apply.
- SCPs cannot be overridden by the local administrator.

Best practice

It's easier to define policies across multiple accounts in an SCP than to replicate these permissions settings into IAM policy documents in each account.

Examples of scenarios defined in SCPs

- Block service access or specific actions. For example, deny users from disabling AWS CloudTrail in all member accounts.
- Enforce the tagging of resources. For example, do not allow users to launch an Amazon Elastic Compute Cloud (Amazon EC2) Amazon Machine Image (AMI) unless it has a specific tag on it.
- Prevent member accounts from leaving the organization.

Example SCP

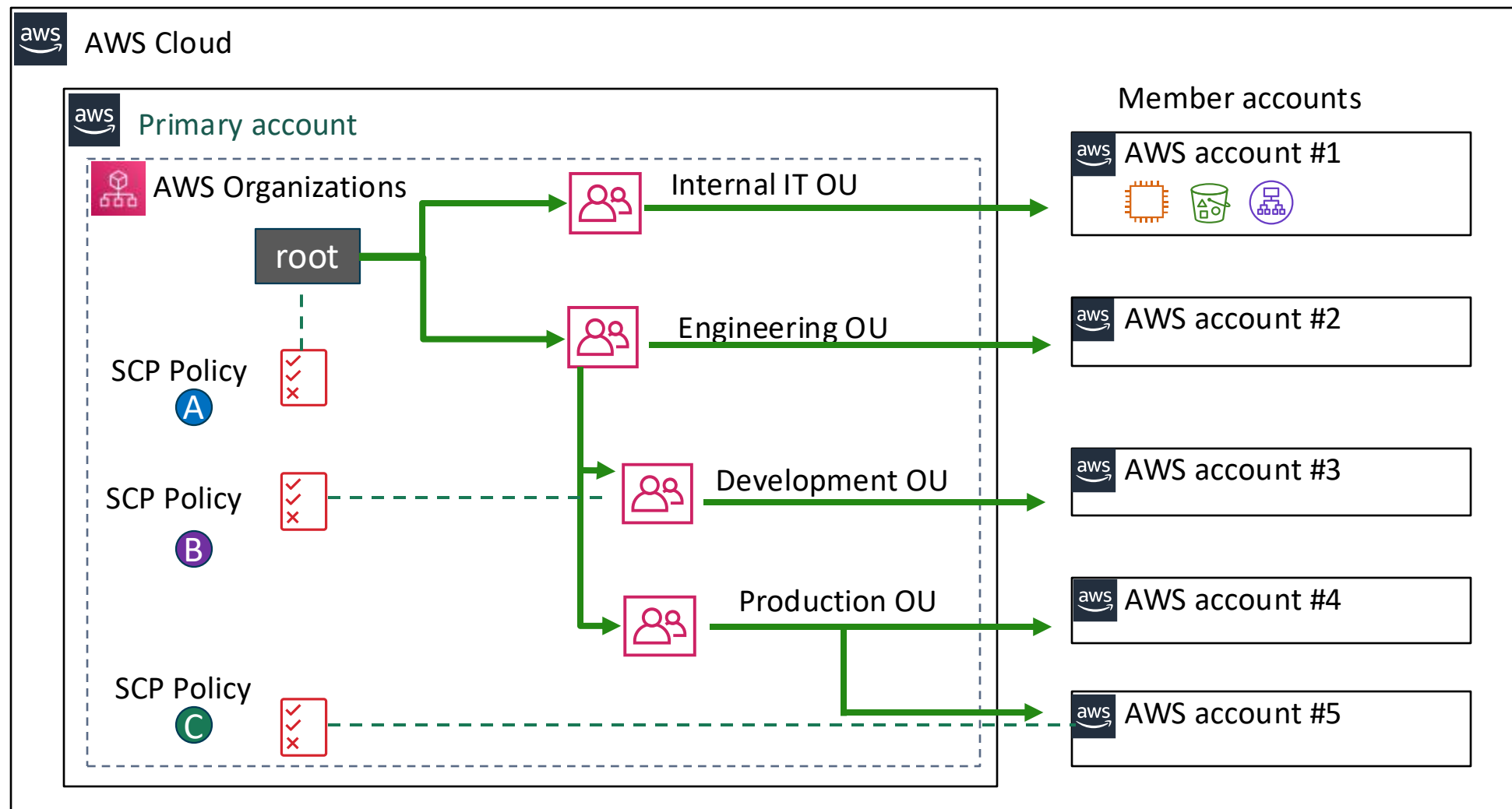
Prevent member accounts from leaving the organization:

```
{
  "Version": "2023-06-17",
  "Statement": [
    {
      "Effect": "Deny",
      "Action": [ "organizations:LeaveOrganization" ],
      "Resource": "*"
    }
  ]
}
```

AWS Organizations: Attach SCPs

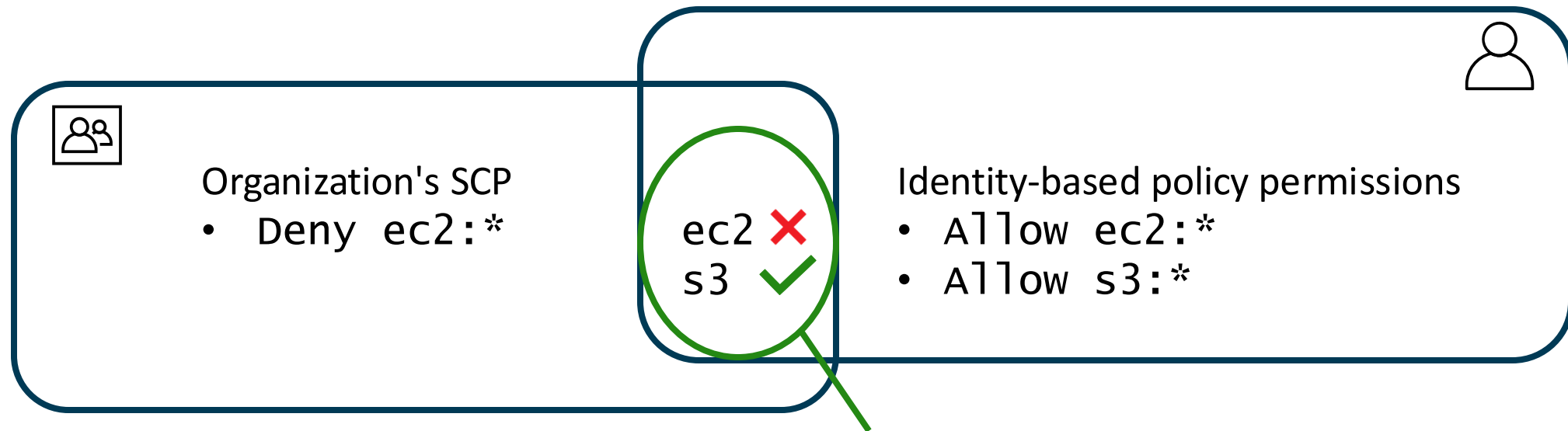
In the AWS Organizations primary account:

1. Create a hierarchy of organizational units (OUs).
2. Assign accounts to OUs as member accounts.
3. Define SCPs that apply permissions restrictions to specific member accounts.
4. Attach the SCPs to root, OUs, or accounts.



Combining SCPs with IAM identity-based policies

Permissions granted are those allowed in both an SCP and an IAM identity-based permissions policy



Permissions boundaries set limits on IAM entities

This permission boundary allows access to only Amazon S3, Amazon CloudWatch, and Amazon EC2

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": [
        "s3:*",
        "cloudwatch:*",
        "ec2:*"
      ],
      "Resource": "*"
    }
  ]
}
```

This identity-based policy grants a user permission to create IAM users

```
{
  "Version": "2012-10-17",
  "Statement": {
    "Effect": "Allow",
    "Action": "iam:CreateUser",
    "Resource": "*"
  }
}
```

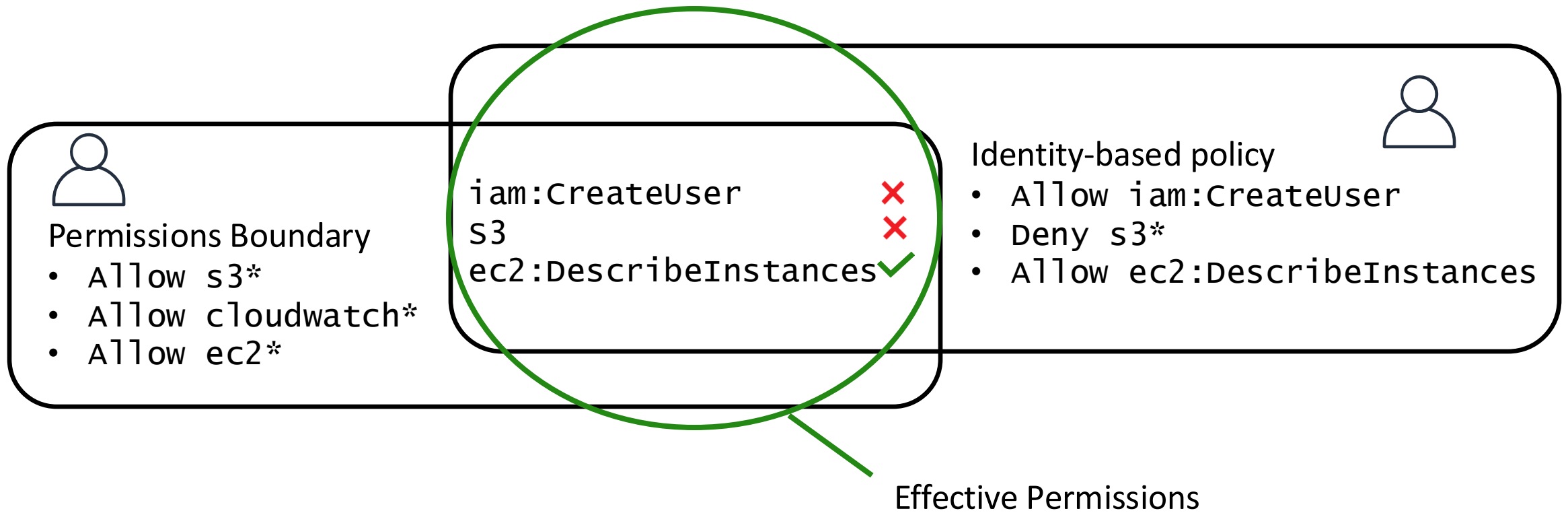


IAM user

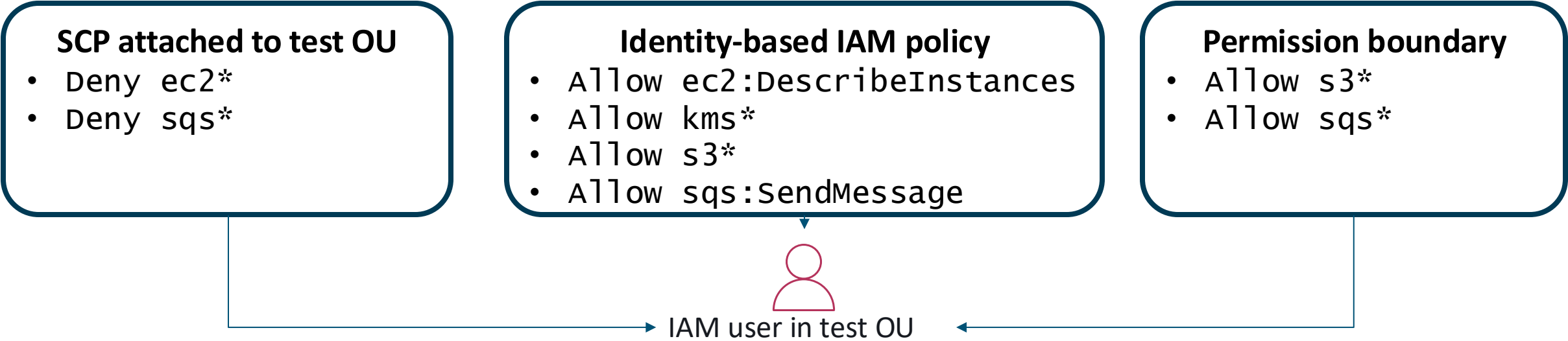


The permission boundary does not include access to IAM, so the identity policy will fail to grant the iam:CreateUser permission to this user.

Permissions must be allowed by both policy types



How multiple policy types impact permissions

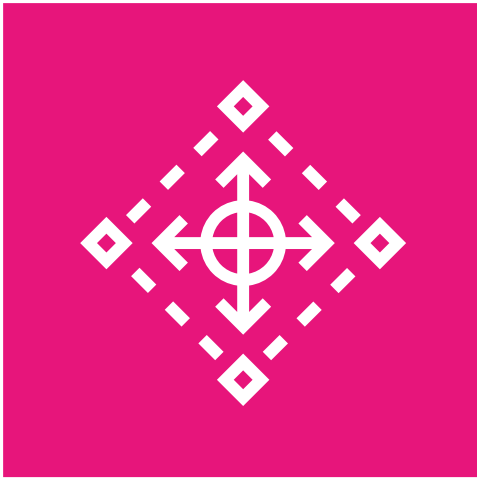


Resource or permission	Allowed?	Rationale
EC2 describe instances	No	Explicit deny to EC2 in SCP overrides allow in IAM policy.
AWS Key Management Service (AWS KMS)	No	There is no explicit deny, but this service is not within the permission boundary.
Amazon S3	Yes	S3 is within the permission boundary and there is no explicit deny in the SCP. The IAM policy grants access.
Amazon Simple Queue Service (Amazon SQS) send message	No	Explicit deny in SCP overrides the allow in the permission boundary and IAM policy.

Comparing permission boundaries and SCPs

Permission boundary	Organizational SCP
Applies to an IAM entity (user or role)	Applies to all members of an organization or OU
Defines the maximum permissions that the associated identity-based policies can grant to an entity	Defines the maximum permissions for account members of an organization or organizational unit (OU)
Does not grant permissions	Does not grant permissions
Typically used to scope which resources a user or role is allowed to access	Typically used to deny access to a set of resources
Example: Allow the IAM role developer to access EC2, Amazon S3, and Amazon CloudWatch. Result: The developer role can only access EC2, Amazon S3, and CloudWatch regardless of other policies associated with their role.	Example: Deny access to Amazon Relational Database Service (Amazon RDS) to all members of the Internal IT OU. Result: All members of the Internal IT OU will be denied access to Amazon RDS regardless of other policies associated with their identity.

AWS Control Tower



AWS Control Tower

- AWS Control Tower facilitates the set up and governance of a secure, multi-account AWS environment.
- AWS Control Tower benefits include the following:
 - Automated set up of a new well-architected multi-account environment based on best practices blueprints
 - Governance of AWS workloads with rules for security, operations, and internal compliance
 - Prescriptive guidance to govern your AWS environment at scale

Key takeaways: Managing access to multiple accounts



- Most organizations choose to create multiple AWS accounts and define a VPC in each account.
- Multiple accounts allow for billing consolidation to help save money by grouping together with tiered pricing. It also enables organizations to cleanly separate different types of resources while providing some security benefits.
- AWS Organizations allows you to consolidate multiple AWS accounts into a centrally managed organization.
- SCPs allow you to set limits on permissions across an organization, while permissions boundaries let you set limits on IAM entities (users and roles).
- Users or groups can have multiple policies attached to them that grant different permissions. If a user isn't granted an explicit permission for an action and a resource, the user doesn't have those permissions.



Encrypting data at rest

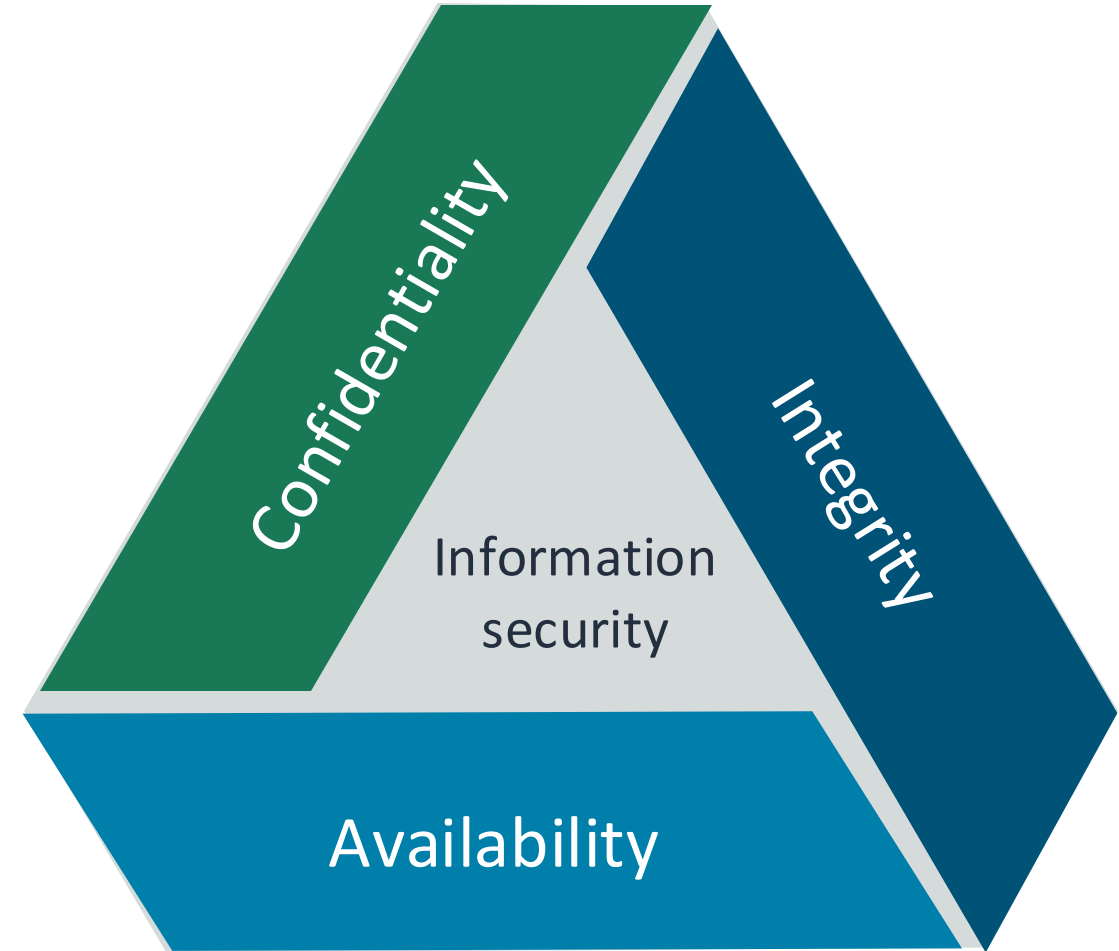
Securing User, Application, and Data Access

Why protect data at rest?

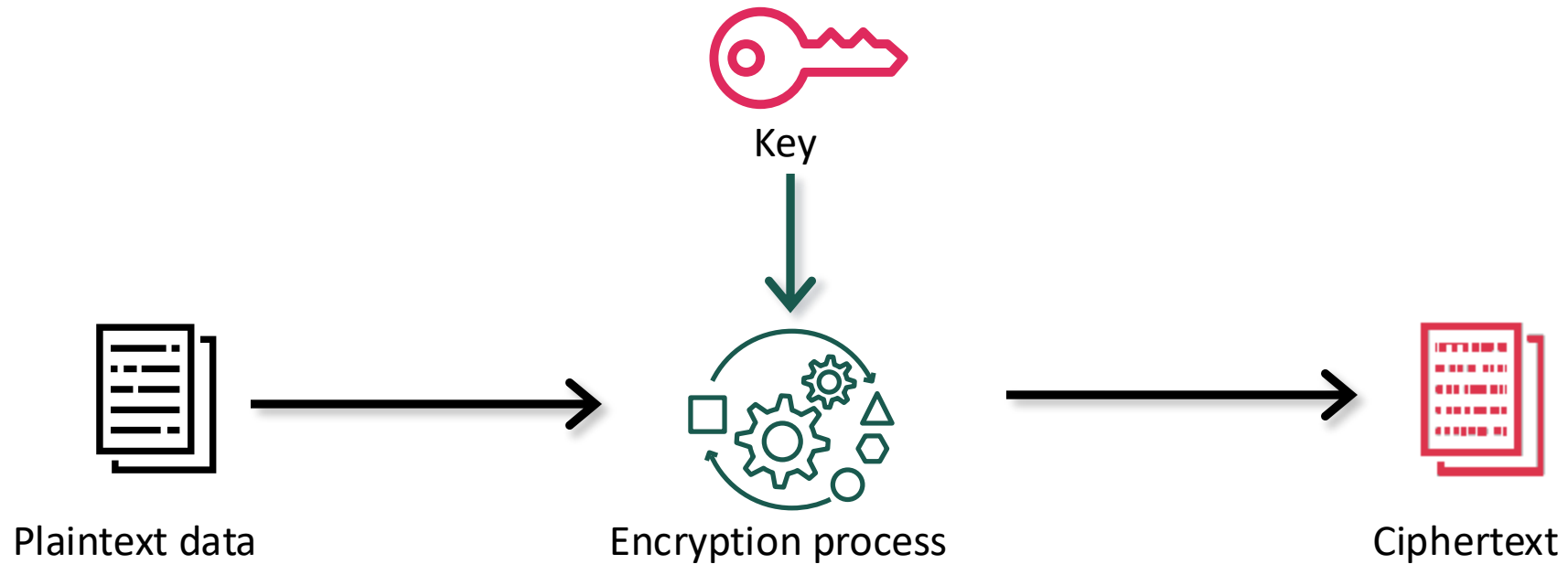
Protecting data at rest does the following:

- Ensures the confidentiality and integrity of information
- Provides an extra layer of protection if your system is compromised

Encryption helps protect data at rest.

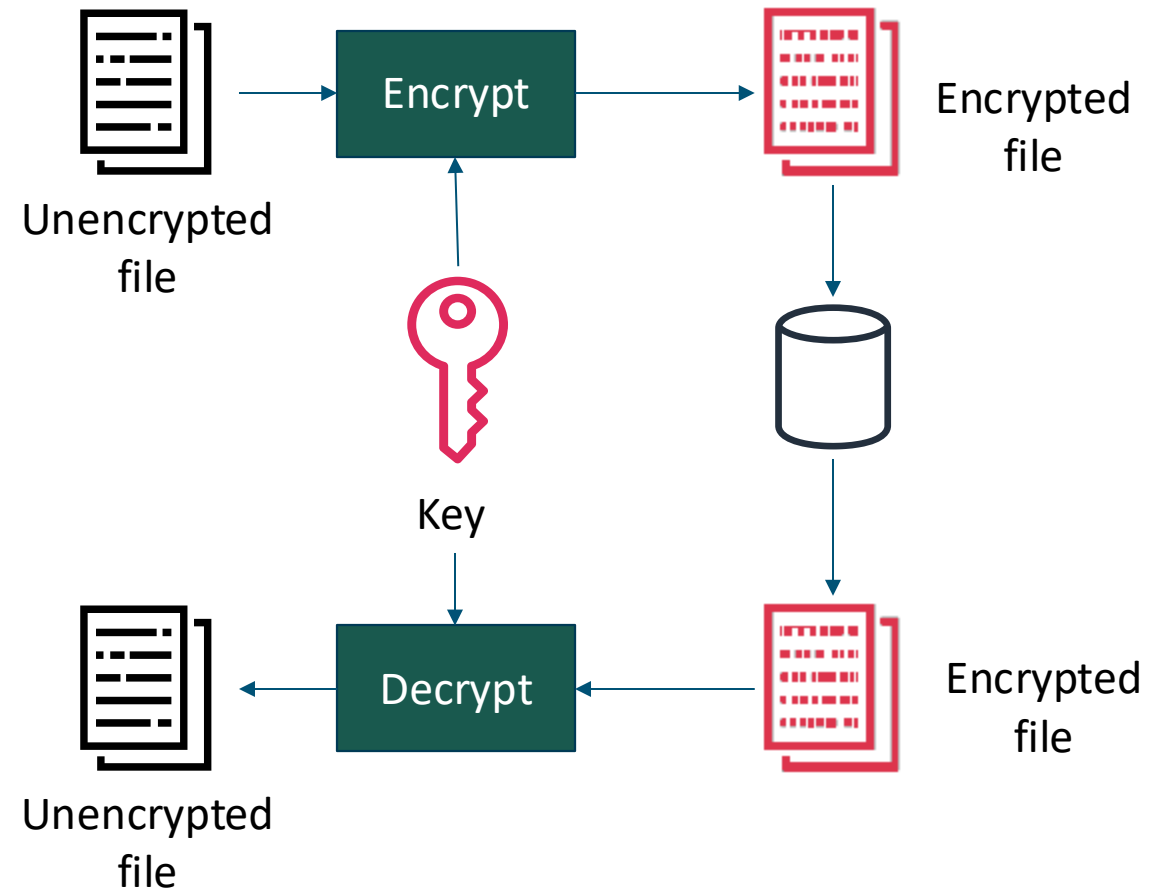


What is data encryption?



Symmetric encryption

- Uses same key to encrypt and decrypt the data
- Typically faster and efficient for large amounts of data
- Widely used and generally accepted to be secure

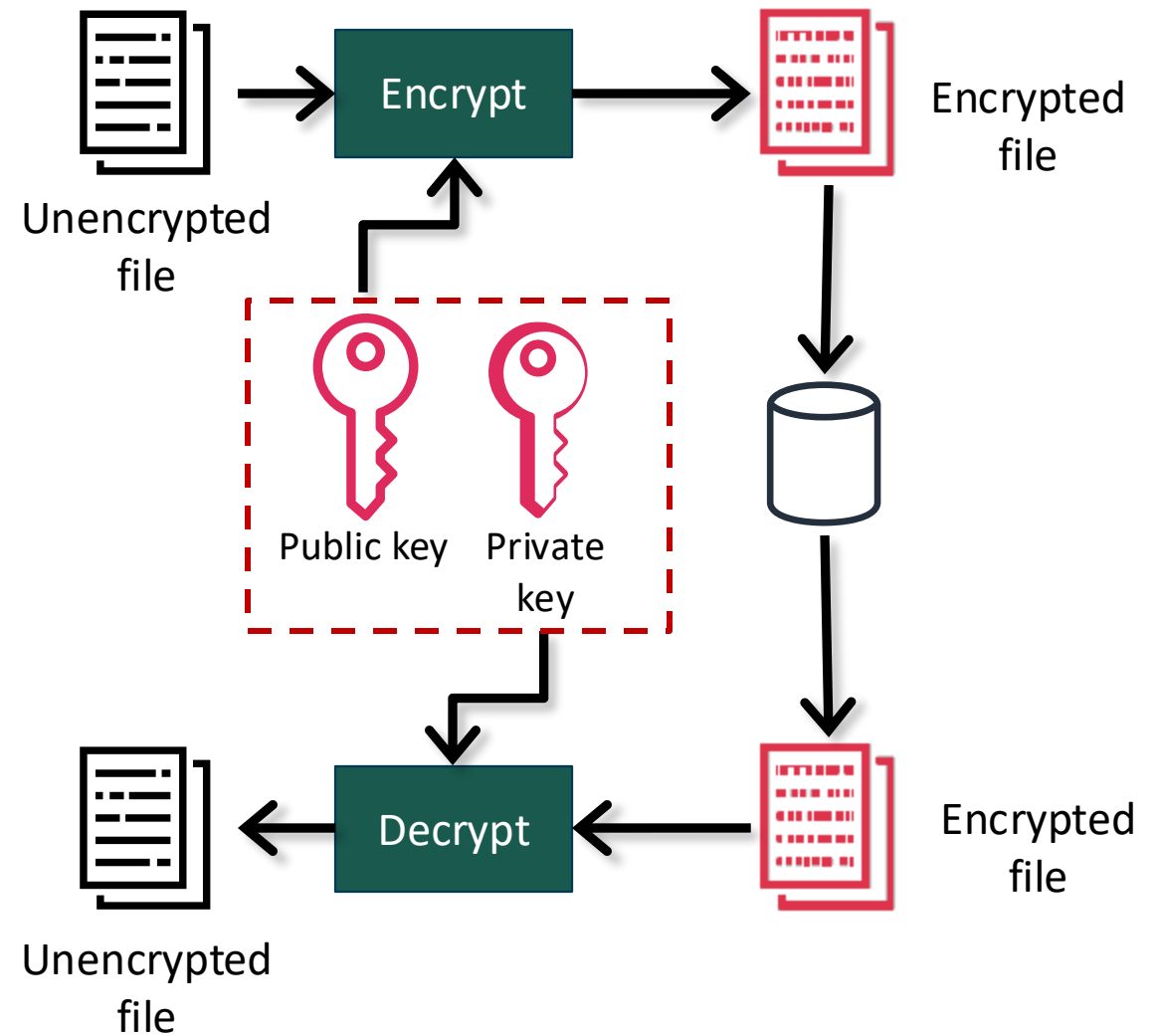


When to use symmetric encryption

- If speed, cost, and lower computational overhead are a priority
- If you're encrypting a large amount of data
- If encrypted data isn't leaving the boundaries of the organization's network

Asymmetric encryption

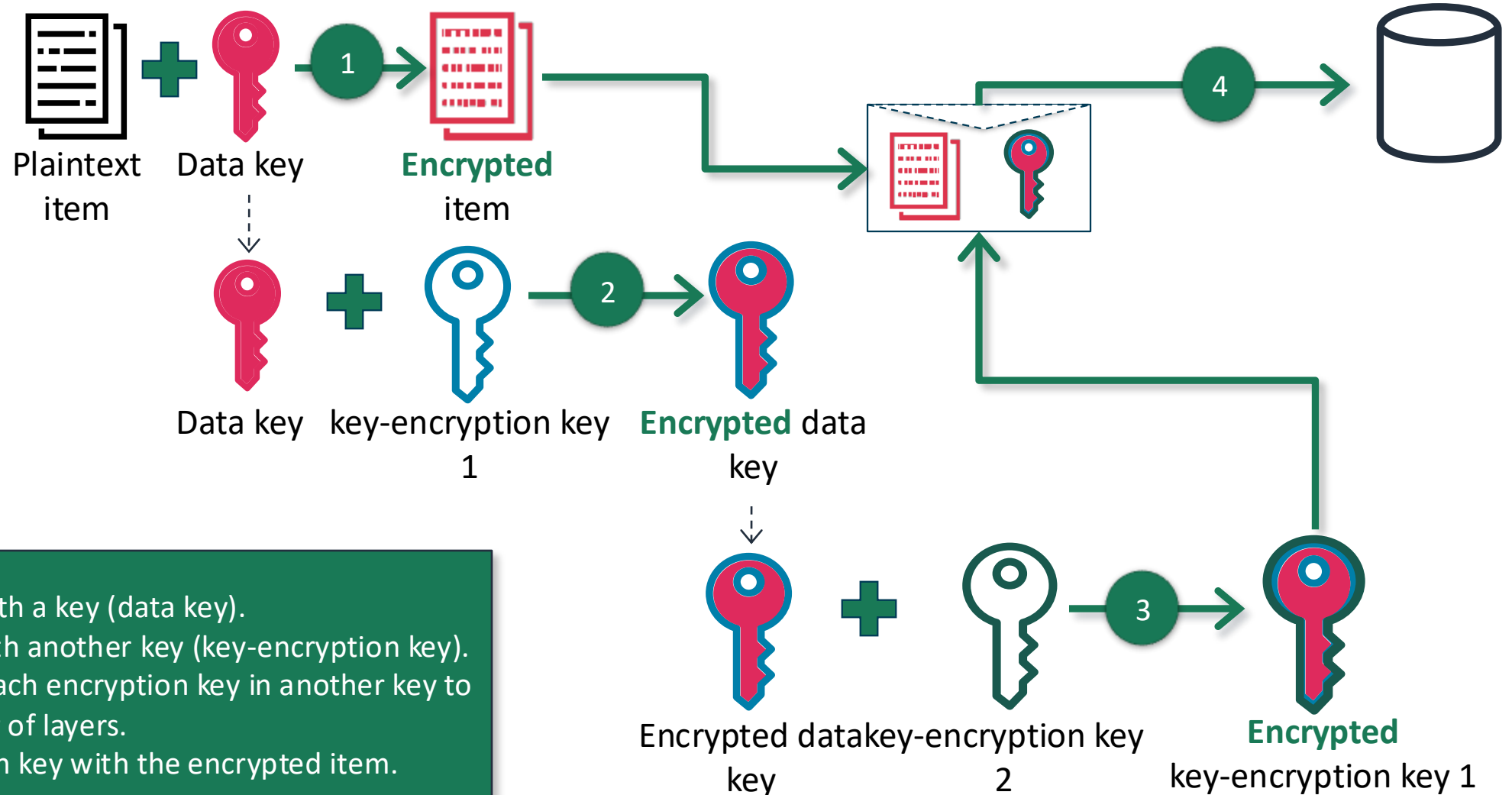
- Uses a key pair: a public key for encryption and a private key for decryption
- Generally regarded to be more secure than symmetric encryption, but it is slower



When to use asymmetric encryption

- If you're sharing the data outside of the organization
- If regulations or governance prohibit sharing the key
- If non-repudiation is required (Non-repudiation prevents a user from denying prior commitments or actions)
- If you're strictly segregating access to encryption keys based on organization roles

Applying envelope encryption

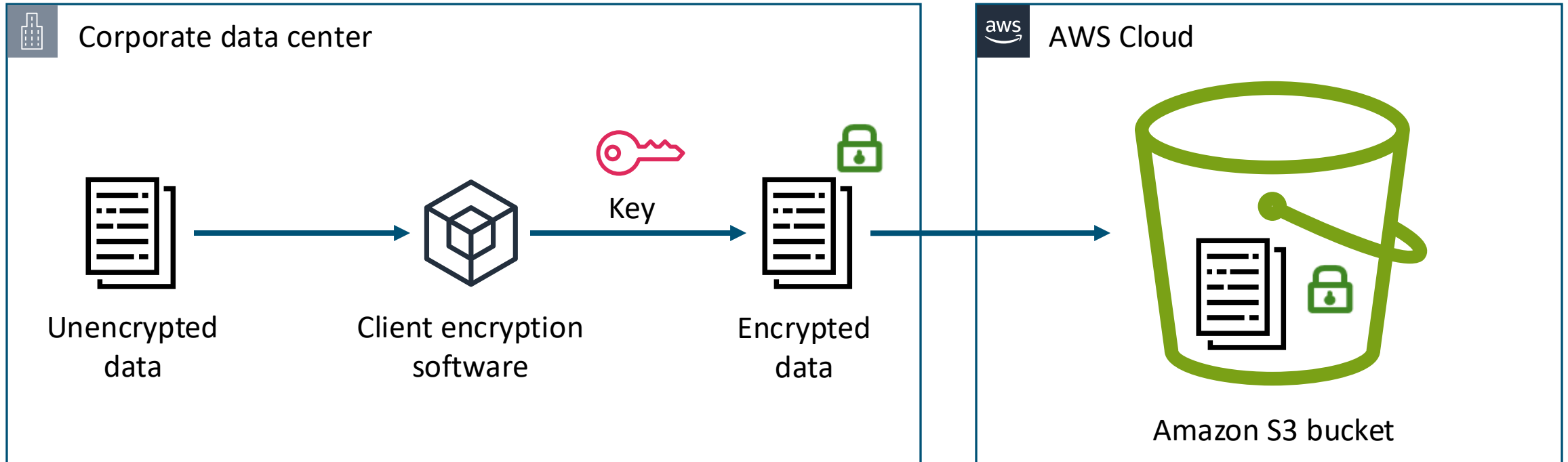


1. Encrypt the item with a key (data key).
2. Encrypt that key with another key (key-encryption key).
3. Continue to wrap each encryption key in another key to the desired number of layers.
4. Store the encryption key with the encrypted item.

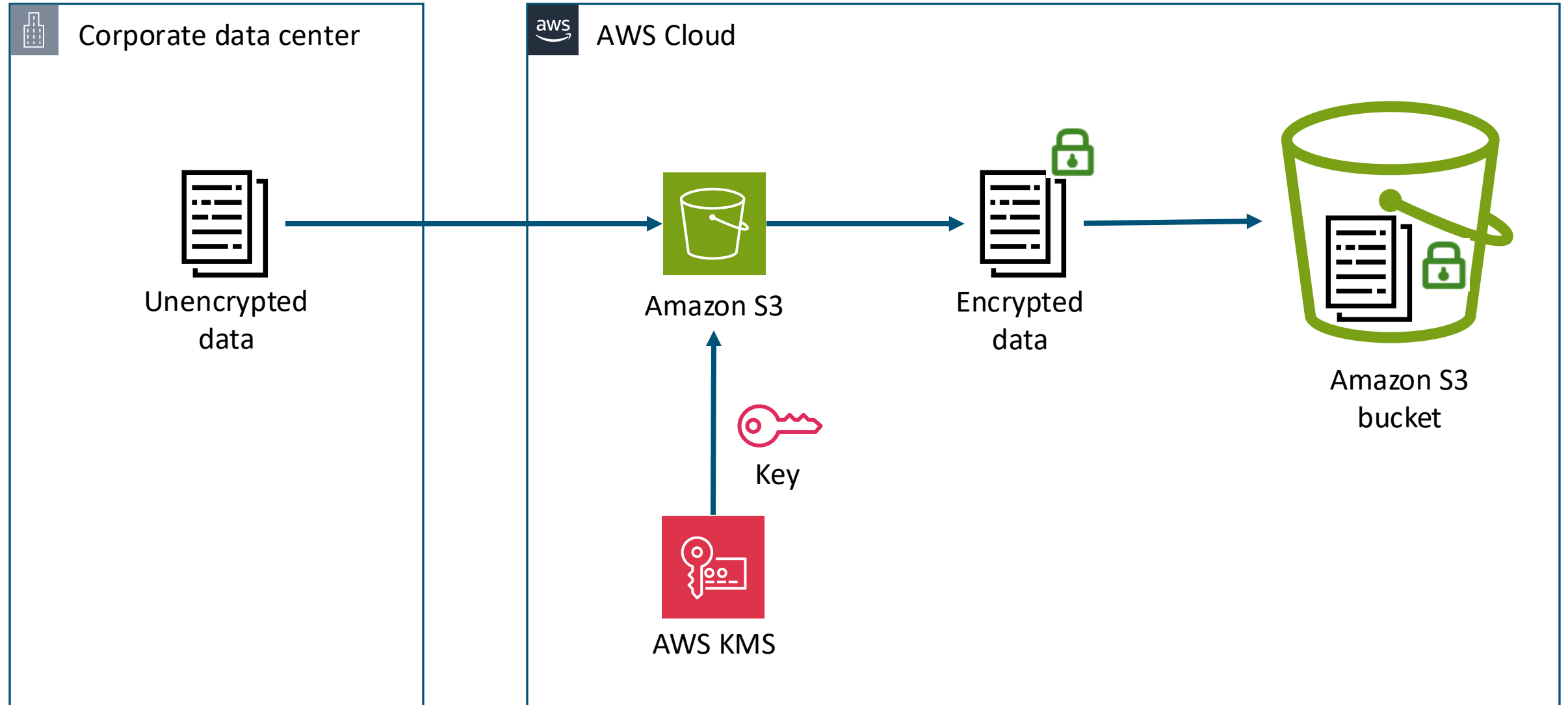
Methods of applying encryption to data at rest

Client-side encryption (CSE)	Server-side encryption (SSE)
The application encrypts data before sending it to AWS.	AWS encrypts data on your behalf after receiving it.
Create and manage your own encryption keys.	Services transparently encrypt your data before writing it to disk and transparently decrypt the data when you access it.
The keys and algorithms are known only to you.	The keys can be managed by AWS.

Client-side encryption example



Server-side encryption example



AWS Key Management Service (AWS KMS)



AWS KMS

- Provides the ability to create and manage cryptographic keys
- Uses hardware security modules (HSMs) to protect your keys
- Integrates with other AWS services
- Provides the ability to set usage policies to determine which users can use keys

AWS KMS features

Keys

- Customer managed
- KMS managed
- Data key (symmetric)
- Data key pair (asymmetric)

Cryptographic operations

- Encrypt
- Decrypt
- GenerateDataKey
- GenerateDataKeyPair

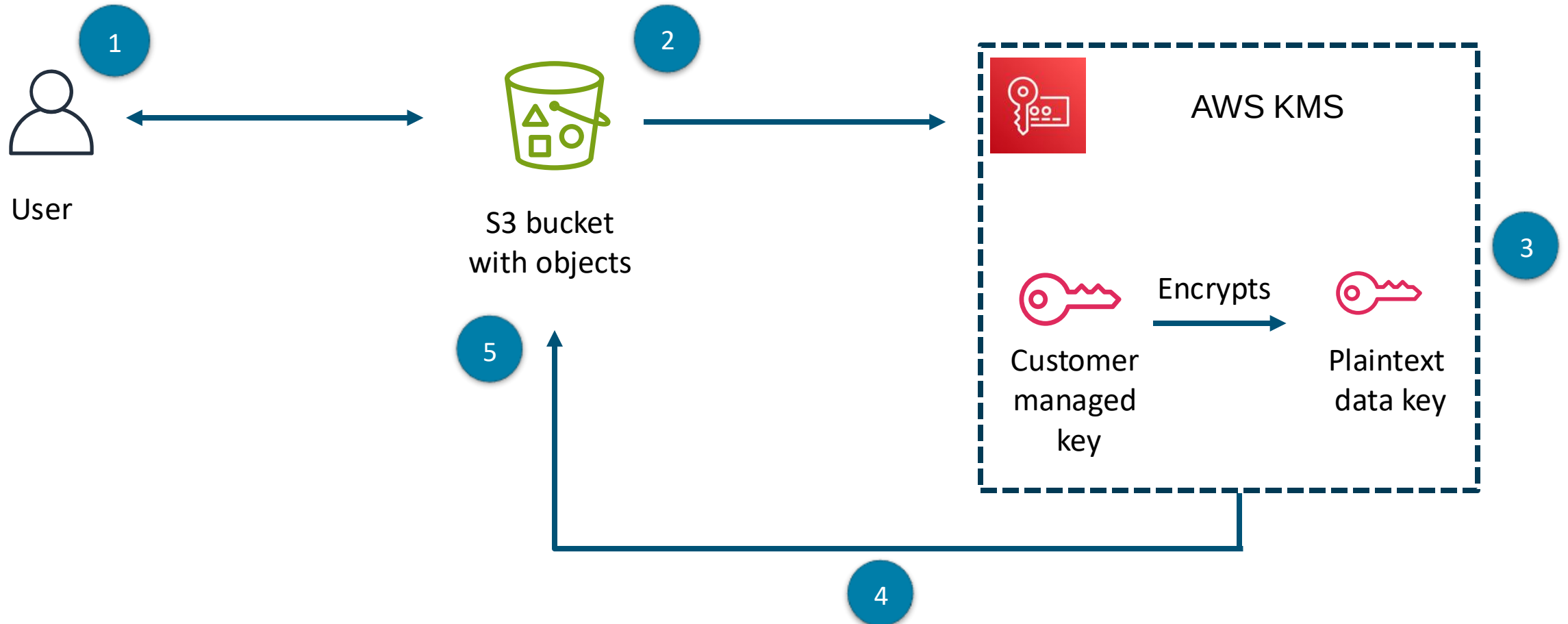
AWS KMS integration with other AWS services

- Amazon Simple Storage Service (Amazon S3)
- Amazon Elastic Block Store (Amazon EBS)

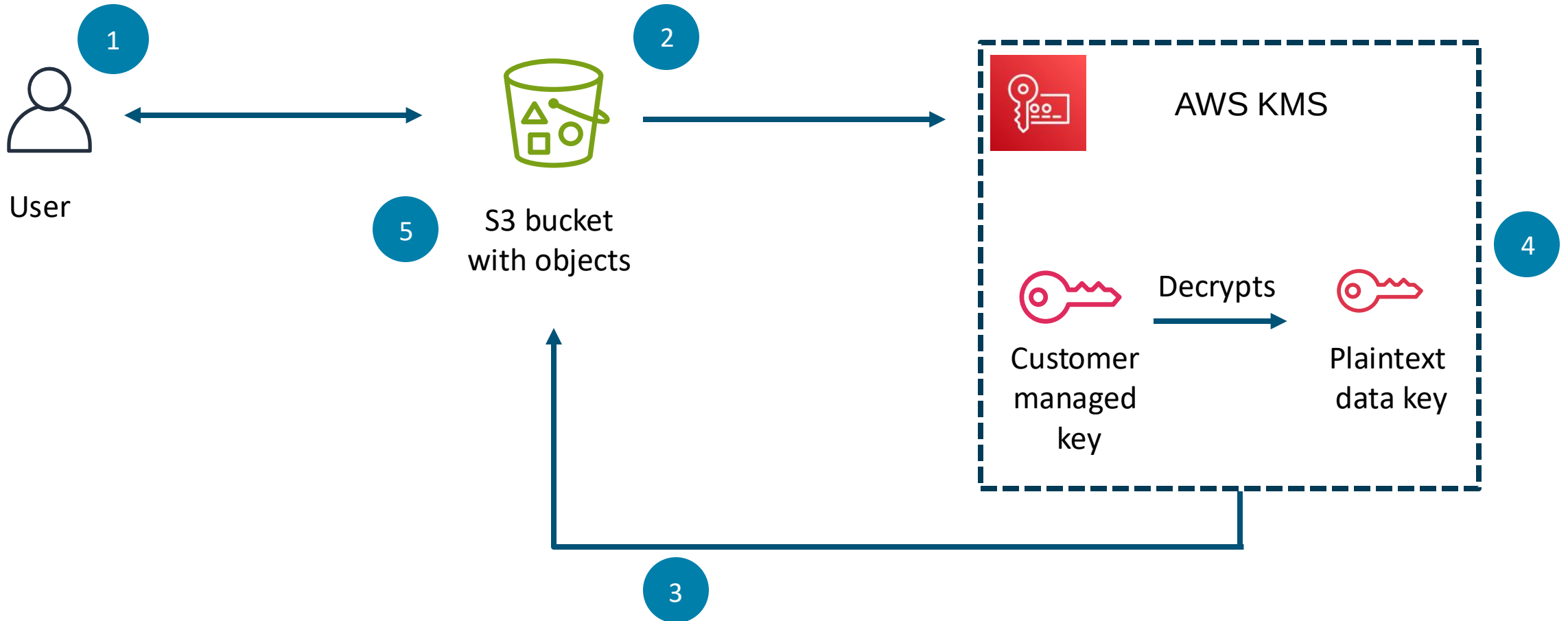
Important

AWS services that are integrated with AWS KMS use only symmetric encryption KMS keys to encrypt your data. These services do not support encryption with asymmetric KMS keys.

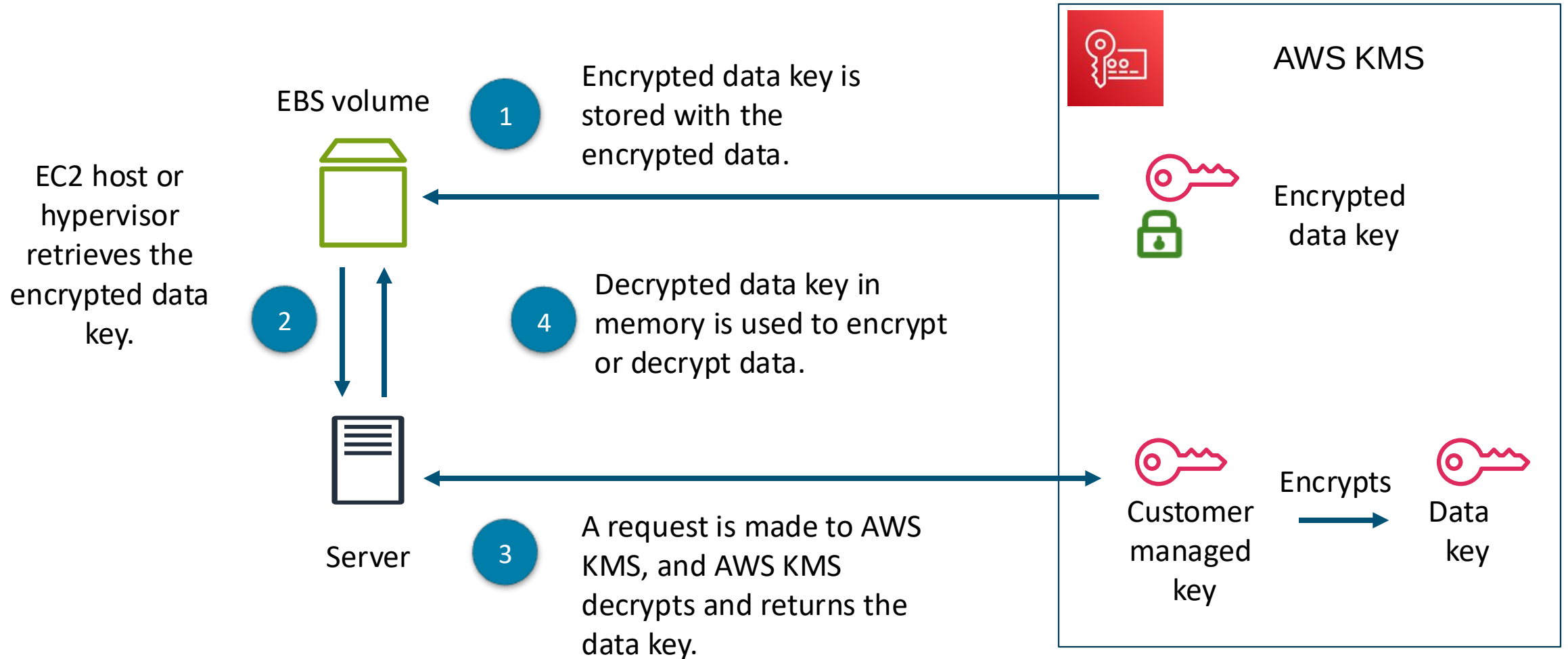
AWS KMS encryption example with Amazon S3



AWS KMS decryption example with Amazon S3



AWS KMS example with Amazon EBS



Key takeaways: Encrypting data at rest



- Encrypting data at rest makes it more difficult for attackers to compromise data, even if they can compromise an endpoint.
- Symmetric encryption uses the same key to encrypt and decrypt the data.
- Asymmetric encryption uses a pair of keys: a public key for encryption and a private key for decryption.
- Envelope encryption is the practice of encrypting plaintext data with a data key, and then encrypting the data key under another key.
- With CSE, your applications encrypt data locally before submitting it to AWS and decrypt data after receiving it from AWS.
- With SSE, data is encrypted at its destination by the application or service that receives it.
- AWS KMS keys are the primary resource in AWS KMS. Use an AWS KMS key to encrypt, decrypt, and re-encrypt data.



Guided lab: Encrypting Data at Rest by Using AWS Encryption Options (AWS KMS lab)

Lab introduction: AWS KMS lab



- In this lab, you use the AWS Key Management Service (AWS KMS) to encrypt data at rest.
- The tasks that you perform include the following:
 - Creating an AWS KMS key
 - Encrypting an object stored in Amazon Simple Storage Service (Amazon S3)
 - Encrypting an Amazon Elastic Block Store (Amazon EBS) volume
 - Auditing AWS KMS key usage using AWS CloudTrail
- Open your lab environment to start the lab and find additional details about the tasks that you will perform.

Debrief: AWS KMS lab

- In this lab, you created an AWS KMS key. What are the differences between a key administrator and a key user?
- Why was it necessary to detach the encrypted EBS volume from the instance to see how disabling the AWS KMS key would affect the volume?



AWS security services for securing user, application, and data access

Securing User, Application, and Data Access

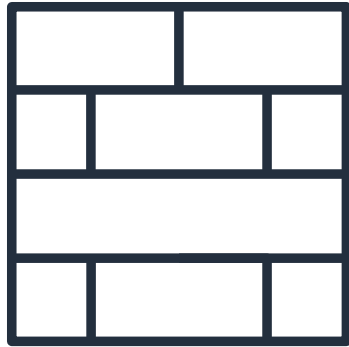
AWS Services for Security, Identity, and Compliance

Category	Category description	Examples
Identity and access management	Securely manage identities, resources, and permissions at scale.	AWS Identity and Access Management (IAM) AWS IAM Identity Center Amazon Cognito AWS Organizations
Detection and response	Enhance security posture and streamline security operations across an entire AWS environment.	AWS CloudTrail Amazon Detective Amazon Inspector AWS Security Hub
Network and application protection	Enforce fine-grained security policies at network control points across an organization.	AWS Network Firewall AWS Shield AWS WAF
Data protection	Protect data, accounts, and workloads from unauthorized access.	AWS Key Management System (AWS KMS) AWS Secrets Manager Amazon Macie
Compliance	Get a comprehensive view of compliance status and continuously monitor using automated checks based on AWS best practices and industry standards.	AWS Artifact AWS Audit Manager

Find the complete list and links to service pages at: <https://aws.amazon.com/products/security/>



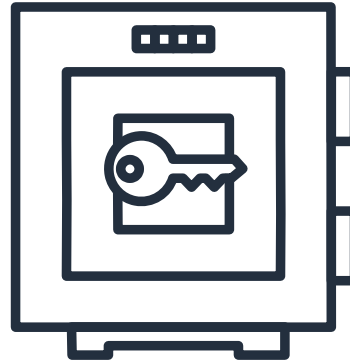
Examples: AWS security services for defense in depth



Defend your borders



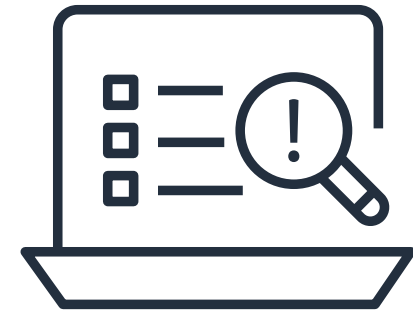
- AWS WAF and AWS Shield



Protect your data



- Amazon Macie



Detect and respond to threats



- Amazon Inspector



- Amazon Detective



- AWS Security Hub



AWS WAF

Description

- A web application firewall that lets you monitor the HTTP and HTTPS requests that are forwarded to your protected web application resources

Features

- Use managed or custom rules.
- Allow or block requests based on things like IP address, country of origin, or header values.
- Use AWS Shield (included at no additional cost) to help minimize the impact of distributed denial of service (DDoS) attacks.

Example use cases

- Block requests that are missing the HTTP User-Agent header.
- Detect and manage malicious account creation attempts on the application's sign-up page.



Amazon Macie

Description

- A data security service that discovers sensitive data stored in Amazon Simple Storage Service (Amazon S3) by using machine learning and pattern matching, provides visibility into data security risks, and enables automated protection against those risks

Features

- Perform automated sensitive data discovery.
- Create and run sensitive data discovery jobs.
- Use built-in or custom data identifiers.
- Review, analyze, and manage findings.

Example use case

- Use Macie to identify sensitive data being migrated into Amazon S3. Notify an administrator to review the data and decide whether to allow process to continue putting the objects into Amazon S3.



Amazon Inspector

Description

- A vulnerability management service that continuously scans your AWS workloads for software vulnerabilities and unintended network exposure
- Discovers and scans running Amazon Elastic Compute Cloud (Amazon EC2) instances, container images in Amazon Elastic Container Registry (Amazon ECR), and AWS Lambda functions

Features

- Centrally manage your environment through a single account by using AWS Organizations.
- Assess vulnerabilities accurately with the Amazon Inspector Risk score.
- Identify high-impact findings with the Amazon Inspector dashboard.
- Publish findings to Amazon EventBridge to support integration with other services.

Example use case

- Scan EC2 Amazon Machine Images (AMIs) and generate Amazon Inspector finding reports to help ensure that your AMIs are scanned for known vulnerabilities and updated prior to deployment.



Amazon Detective

Description

- Helps analyze, investigate, and quickly identify the root cause of security findings or suspicious activities
- Automatically collects log data from AWS resources and uses machine learning, statistical analysis, and graph theory to generate visualizations that support faster and more efficient security investigations

Features

- View data organized into a pre-built graph model with security-related relationships. The model summarizes contextual and behavioral insights.
- Quickly validate, compare, and correlate the data to reach conclusions.
- Automatically ingest and process relevant data from all enabled accounts.

Example use case

- Triage a potential issue by finding all activity related to a specific IAM entity.



AWS Security Hub

Description

- Collects security data across AWS accounts, AWS services, and supported third-party products
- Helps you analyze your security trends and identify the highest priority security issues

Features

- Supports multiple security standards including the AWS Foundational Security Best Practices (FSBP) and external compliance frameworks
- Receives findings from other AWS services including Amazon Macie and Amazon Inspector
- Uses automation rules to automatically update critical findings when a security check fails

Example use case

- Better prioritize the response and remediation efforts of security teams by searching, correlating, and aggregating diverse security findings by accounts and resources.

Using AWS Security Hub with AWS Trusted Advisor



Trusted Advisor

- It provides recommendations based on five categories of AWS best practices: cost optimization, security, fault tolerance, service limits, and performance improvement.
- It evaluates your account to suggest improvements and optimizations for your resources.
- Access Trusted Advisor through the AWS Management Console, and it's available to all support tiers.
- After enabling Security Hub for your AWS account, view your security controls and findings in the Trusted Advisor console.

Key takeaways: AWS security services



- AWS security services help you implement a defense in depth strategy to your AWS workloads.
- Security services examples include the following:
 - AWS WAF to monitor web requests
 - Amazon Macie to identify sensitive data in Amazon S3
 - Amazon Inspector to identify vulnerabilities on EC2 instances, containers, and AWS Lambda functions
 - Amazon Detective to analyze, investigate, and quickly identify the root cause of security findings or suspicious activities
 - AWS Security Hub to automatically consolidate findings and help you monitor your cloud security posture against best practices
- AWS Trusted Advisor inspects your AWS environment and then makes recommendations when opportunities exist to help close security gaps. AWS Security Hub recommendations are included in Trusted Advisor.



Module wrap-up

Securing User, Application, and Data Access

Module summary

This module prepared you to do the following:

- Use AWS Identity and Access Management (IAM) users, groups, and roles to manage permissions.
- Implement user federation within an architecture to increase security.
- Describe how to manage multiple AWS accounts.
- Recognize how AWS Organizations service control policies (SCPs) increase security within an architecture.
- Encrypt data at rest by using AWS Key Management Service (AWS KMS).
- Identify appropriate AWS security services based on a given use case.

Module knowledge check



- The knowledge check is delivered online within your course.
- The knowledge check includes 10 questions based on material that was presented on the slides and in the slide notes.
- You can retake the knowledge check as many times as you like.

Sample exam question

A company has two separate AWS accounts for testing workloads: one for performance testing and the other for integration testing. The accounts are grouped into an AWS Organizations organizational unit, and each account has a Tester role defined. The company wants to enforce the following security rules on users in the Tester role (testers) in both accounts:

- Testers can only access the Amazon EC2 and Amazon RDS services.
- Testers can only start and stop EC2 instances.
- Testers have read and write permissions to RDS databases.

Which tasks does a system administrator need to perform to implement these requirements? (Select TWO).

Identify the key words and phrases before continuing.

The following are the key words and phrases:

- The accounts are grouped into an AWS Organizations organizational unit.
- Each account has a Tester role.
- Enforce the following security rules on users in the Tester role (testers) in both accounts.
- Testers can only access the Amazon EC2 and Amazon RDS services.

Sample exam question: Response choices

A company has two separate AWS accounts for testing workloads: one for performance testing and the other for integration testing. The accounts are grouped into an AWS Organizations organizational unit, and each account has a Tester role defined. The company wants to enforce the following security rules on users in the Tester role (testers) in both accounts: Testers can only access the Amazon EC2 and Amazon RDS services, testers can only start and stop EC2 instances, and testers have read and write permissions to RDS databases.

Which tasks does a system administrator need to perform to implement these requirements? (Select TWO).

Choice	Response
A	Create a service control policy (SCP) to deny all actions on all AWS services except for the Amazon EC2 and Amazon RDS services, and attach it to the Tester role in both accounts.
B	Create an AWS Identity and Access Management (IAM) policy with the required EC2 and RDS permissions, and attach it to the organizational unit.
C	Create a service control policy (SCP) to deny all actions on all AWS services except for the Amazon EC2 and Amazon RDS services, and attach it to the organizational unit.
D	Create an AWS Identity and Access Management (IAM) policy in both accounts with the required EC2 and RDS permissions, and attach it to the Tester role.
E	Create a service control policy (SCP) in both accounts with the required EC2 and RDS permissions, and attach it to the Tester role.

Sample exam question: Answer

The correct answers are C and D.

Choice	Response
C	Create a service control policy (SCP) to deny all actions on all AWS services except for the Amazon EC2 and Amazon RDS services, and attach it to the organizational unit.
D	Create an AWS Identity and Access Management (IAM) policy in both accounts with the required EC2 and RDS permissions, and attach it to the Tester role.



Thank you

Corrections, feedback, or other questions?

Contact us at <https://support.aws.amazon.com/#/contacts/aws-academy>.